



HOW TO ALIGN CTI AND RISK MANAGEMENT

Successfully Connecting Two Related Practices



MANDIANT
NOW PART OF Google Cloud



2023 Cyber Threat Intelligence Conference

November 6, 2023 | 11AM-3:45PM

AGENDA

- ▼ INTRODUCTION
- ▼ BASELINE
- ▼ ALIGN
- ▼ ENABLE
- ▼ CONCLUDE

INTRO



**ESTABLISH EXPECTATIONS
AND OUTCOMES.**

**GET *TOO* COMFORTABLE
WITH EACH OTHER.**

WHO ARE WE



JOHN DOYLE



JAMIE COLLIER



GRACE CHI

MANDIANT
NOW PART OF Google Cloud

 **Pulsedive**

CHAPTER 1: WHY CAN'T WE BE FRIENDS?

Ft. Frodo on Vocals



HOUSEKEEPING

The FIRST Program Committee chose thematically similar, complementary workshops this year.

Synergy! The workshop presenters have been working behind the scenes to ensure structural alignment.

Expect to see call outs in this workshop where others one dig deeper into particular areas.



Training: Track 1 Level 2 - MOA 16		Training: Track 2 Level 2 - MOA 14		Training: Track 3 Level 2 - MOA 15
08:30 - 09:00		Threat Quantification & Prioritization 101: A Practical Guide to Building (& Maintaining) Your Cyber Threat Profile (08:30-11:00) <i>Scott Small (Tidal Cyber, US); Simone Kraus</i> TLP: CLEAR		
09:00 - 10:00	Intelligence Planning Workshop - How to Create and Employ an Intelligence Plan that Synchronizes with your Stakeholders Needs (09:00-13:00) <i>Michael DeBolt (Intel 471, US); Freddy Murstad (Nordic Financial CERT, NO)</i> TLP: CLEAR	Threat Quantification & Prioritization 101: A Practical Guide to Building (& Maintaining) Your Cyber Threat Profile (08:30-11:00) <i>Scott Small (Tidal Cyber, US); Simone Kraus</i> TLP: CLEAR		Hunting and Tracking Adversaries (09:00-13:00) <i>Bartek Jerzman (Standard Chartered, PL)</i> TLP: AMBER
10:00 - 10:15	Coffee Break Level 2 Atrium			
10:15 - 11:00	Intelligence Planning Workshop - How to Create and Employ an Intelligence Plan that Synchronizes with your Stakeholders Needs (09:00-13:00) <i>Michael DeBolt (Intel 471, US); Freddy Murstad (Nordic Financial CERT, NO)</i> TLP: CLEAR	Threat Quantification & Prioritization 101: A Practical Guide to Building (& Maintaining) Your Cyber Threat Profile (08:30-11:00) <i>Scott Small (Tidal Cyber, US); Simone Kraus</i> TLP: CLEAR		Hunting and Tracking Adversaries (09:00-13:00) <i>Bartek Jerzman (Standard Chartered, PL)</i> TLP: AMBER 10:15 - 13:00
11:00 - 13:00	10:15 - 13:00	How to Align CTI and Risk Management: Successfully Connecting Two Related Practices (11:00-15:45) <i>Grace Chi (Pulsedive, US); Jamie Collier, John Doyle (US)</i> TLP: CLEAR		
13:00 - 14:00	Lunch Break Level 2 Atrium			
14:00 - 15:45	MISP CTI Analyst Threat Information Creator Workshop (14:00-18:00) <i>Alexandre Dulaunoy, Andras Ikody (CIRCL, LU)</i> TLP: CLEAR	How to Align CTI and Risk Management: Successfully Connecting Two Related Practices (11:00-15:45) <i>Grace Chi (Pulsedive, US); Jamie Collier, John Doyle (US)</i> TLP: CLEAR		'Build Your Own Threat Landscape' Workshop (14:00-18:00) <i>Brian Mohr (Regfast, US); Roman Sannikov (Constellation Cyber LLC, US)</i> TLP: GREEN
15:45 - 16:00	Coffee Break Level 2 Atrium			
16:00 - 18:00	MISP CTI Analyst Threat Information Creator Workshop (14:00-18:00) <i>Alexandre Dulaunoy, Andras Ikody (CIRCL, LU)</i> TLP: CLEAR	Priority Intelligence Requirements Workshop - How to Set the Directions of Your CTI Program <i>Ondra Rojick, Vladimir Janout (Red Hat, CZ)</i> TLP: CLEAR		'Build Your Own Threat Landscape' Workshop (14:00-18:00) <i>Brian Mohr (Regfast, US); Roman Sannikov (Constellation Cyber LLC, US)</i> TLP: GREEN

WORKSHOP WORKBOOK

bit.ly/first23-cti-risk



WORKSHOP WORKBOOK

<https://bit.ly/first23-cti-risk>

HOW TO ALIGN CTI AND RISK MANAGEMENT

Successfully Connecting Two Related Practices

FIRST 2023 Cyber Threat Intelligence Conference

November 6, 2023 | 11AM-3:45PM

Presenters: John Doyle, Jamie Collier, Grace Chi

MANDIANT Pulsedive

Make a copy of this document to follow along the workshop, take notes, and share your thoughts.

1 Why should we integrate CTI and cyber risk?

2 What benefits would this bring your organization?

SIMILARITIES & DIFFERENCES

CTI	

3 What have your experiences been in integrating CTI and risk management?

4 What challenges have you experienced during this process?

RESPONSIBILITY ASSIGNMENT MATRIX

ACTIVITY	RESPONSIBLE	ACCOUNTABLE	CONSULTED	INFORMED
ex. Identify and document cyber threat factors	CTI	CTI	IT Leadership	Risk
Lead cyber risk assessments	Risk	Risk	CTI	IT Leadership
Develop threat models	IT Security	IT Security	Risk & CTI	IT Leadership
Validate cyber threats to crown jewels	CTI (or red team)	Risk	Risk	IT Leadership

VULNERABILITY RESOURCES

- FIRST Common Vulnerability Scoring System (CVSS)
- FIRST's Exploit Prediction Scoring System (EPSS)
- CISA's Known Exploited Vulnerabilities (KEV) Catalog

ORGANIZATIONAL USE CASES

SITUATION REQUIRING ASSESSMENT	CTI CONTRIBUTION	SIMPLE RISK ASSESSMENT	CROWN JEWEL IMPACT	RECOMMENDATION
A command injection vulnerability exists in the Web UI component of Cisco IOS XE versions 16.11.1 and earlier that, when exploited, allows a privileged attacker to remotely execute arbitrary commands with root privileges (CVE-2019-12650). NVD rated this vulnerability to be "high" risk.	CTI rated it as low risk because it requires the highest level of privileges (level 15 admin privileges) to exploit. Because this level of access should be quite limited in enterprise environments, we believe that it is unlikely attackers would be able to leverage this vulnerability as easily as others.	Frequency - No known - Future exploitation unlikely Severity - High	None	Mitigate the risk through patching, and accept the risk until the patch is implemented. The patching schedule likely does not need to be accelerated in this case given low likelihood of exploitation.

WHY WE'RE HERE

CTI and Risk Management are two traditionally separate areas.

Yet there is growing recognition of benefits from coordinating workflows and sharing knowledge between CTI and Risk Management.

Transcending cyber risk-intelligence silos creates synchronized cyber defense organizations, enabling larger strategic initiatives.

CTI | RISK

...but, aligning the two is not always an easy task

The therapy dog
after I share all
my problems:



NOW, WHY ARE
YOU HERE?

DISCUSSION

? Why should we integrate CTI and cyber risk?

? What benefits would this bring your organisation?

TODAY

This workshop **demystifies misconceptions**, **identifies unique elements**, and **highlights differences** that cause friction that inhibits collaboration.

We will jointly **identify collaboration opportunities** unique to your organizational culture and **develop key building blocks** across products and processes to improve collaboration, effectiveness, and resilience.

TOMORROW

After the workshop, you'll be equipped to have **open conversations with partner team(s)** about improving cross-functional collaboration.

You'll have a baseline understanding of unique terminology and frame of reference aligning role and responsibility within the organization to assist in these discussions. Plus, you'll have products or processes to **jumpstart the conversation about creating collaborative workflows.**

PREP

bit.ly/first23-cti-risk

- ☐ MANDIANT ADVANTAGE
- ☐ VIRUSTOTAL
- ☐ PULSEDIVE

LOGIN CREDENTIALS

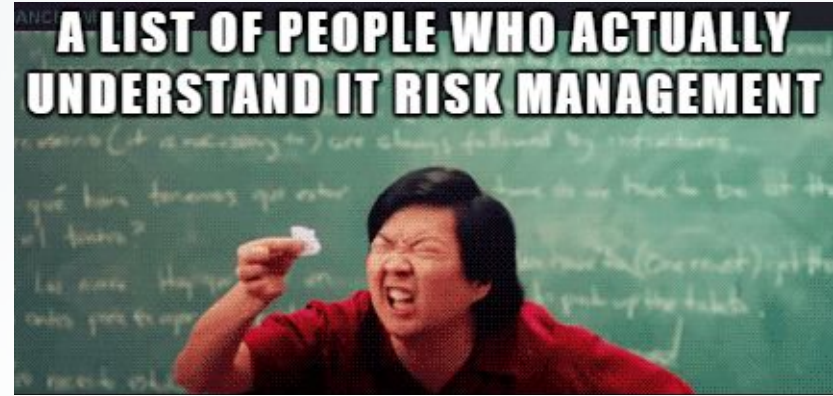
- **Mandiant Advantage** - [REDACTED]
 - Please add your name in student field/row when you take a login
- **VirusTotal** (Shared)
 - Username: [REDACTED]
 - Password: [REDACTED]
- **Pulsedive** - Register free account at <https://pulsedive.com/register>
 - For 2 weeks [Pro](#) access, message grace@pulsedive.com with subject [REDACTED] and **registered email**

CHAPTER 2: THERE CAN BE ONLY ONE

Ft. Smeagol on Keys



BASELINE



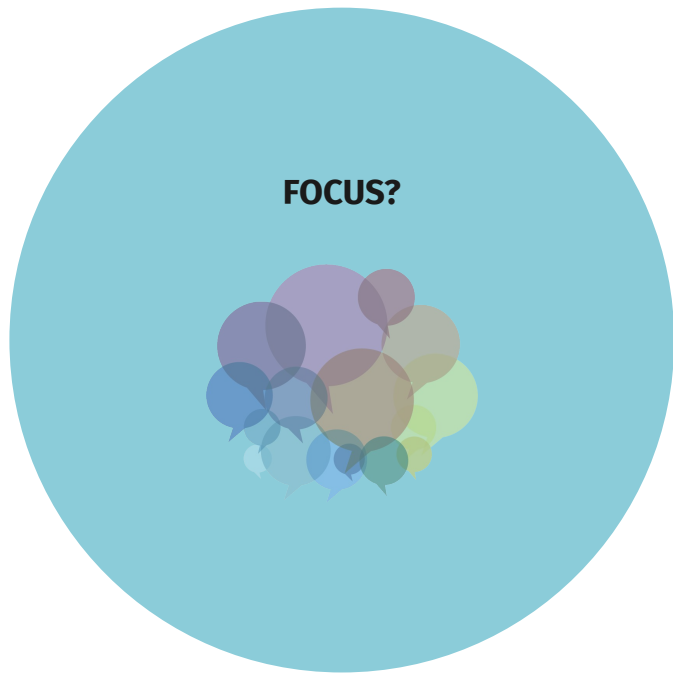
**BUILD A SHARED
UNDERSTANDING OF CTI &
RISK PROFESSIONALS.
RELEASE INHIBITIONS.**

CYBER THREAT INTEL

OVERVIEW

Provide visibility into current and emerging threats and trends to inform cyber security and risk decisions.

This spans across people, processes, and technologies and improve business outcomes.



CYBER THREAT INTEL

OVERVIEW

Provide visibility into current and emerging threats and trends to inform cyber security and risk decisions.

This spans across people, processes, and technologies and improve business outcomes.

FOCUS

Reduce risk
exposure through

Prevention

Detection

Response

Remediation

CYBER THREAT INTEL DELIVERABLES

Strategic

Chief Information Security
Security Management
Risk Management and Analysts
Security Awareness
Board & Executive Team

Operational

Incident Response
Forensics
Red Team
Purple Team

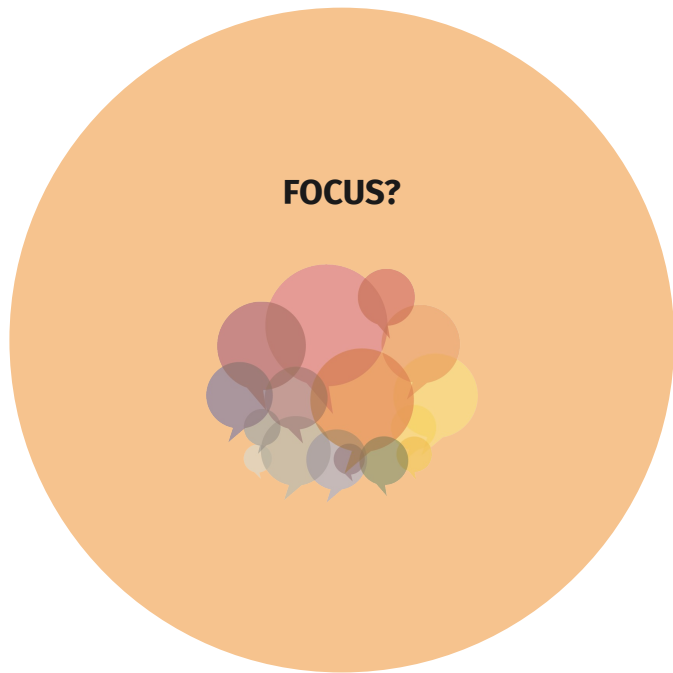
Tactical

Vulnerability & Patch Management
Security Operations Center
Network Operations Center

RISK MANAGEMENT

OVERVIEW

Help decision makers create directional strategies in a deliberate and responsible manner that balance systemic uncertainty against organizational priorities to increase resilience, minimize loss, and continue business operations.



RISK MANAGEMENT

OVERVIEW

Help decision makers create directional strategies in a deliberate and responsible manner that balance systemic uncertainty against organizational priorities to increase resilience, minimize loss, and continue business operations.

FOCUS

Identify

Assess

Communicate

Risks to an
organization

RISK MANAGEMENT DELIVERABLES

Executives & Compliance

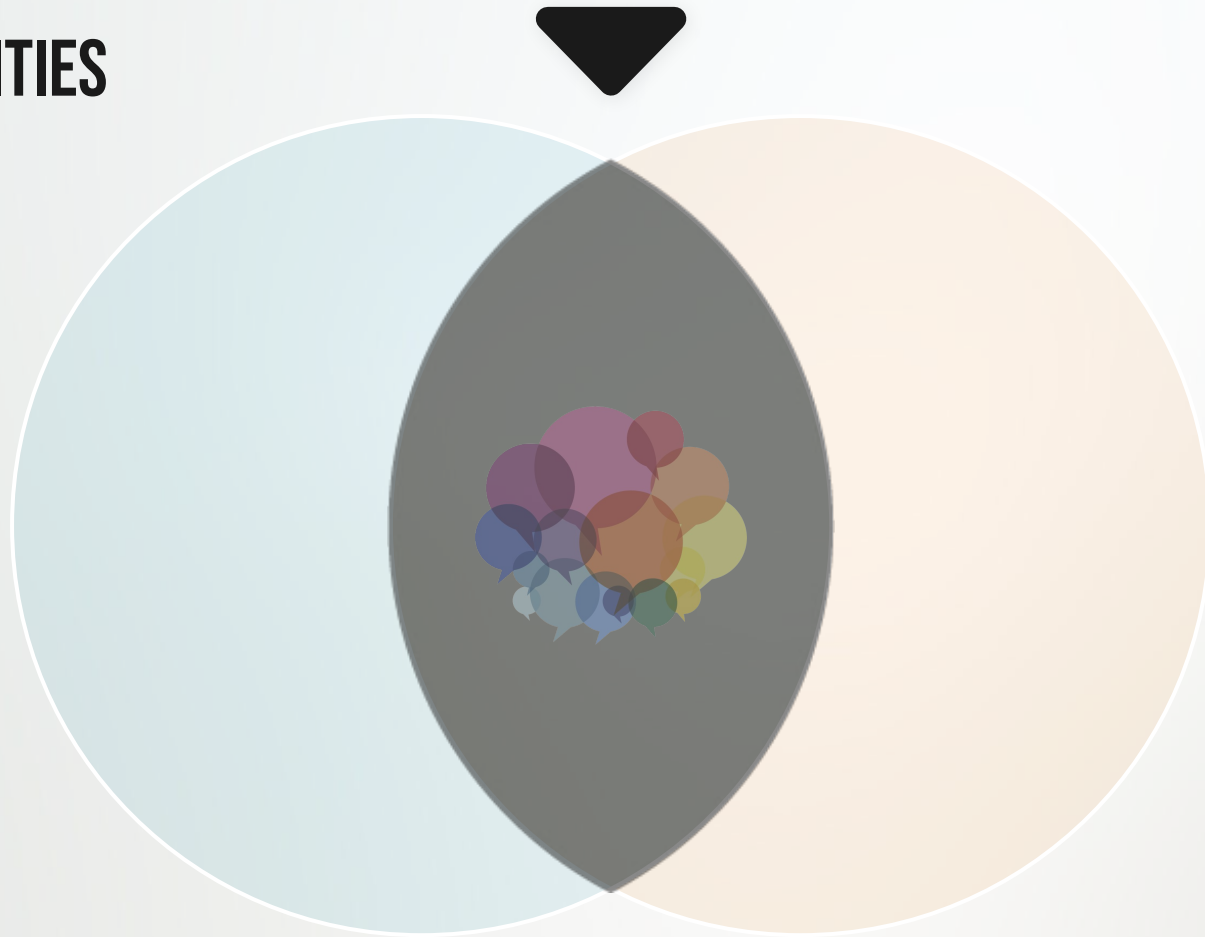
Financial

Strategic

Operational

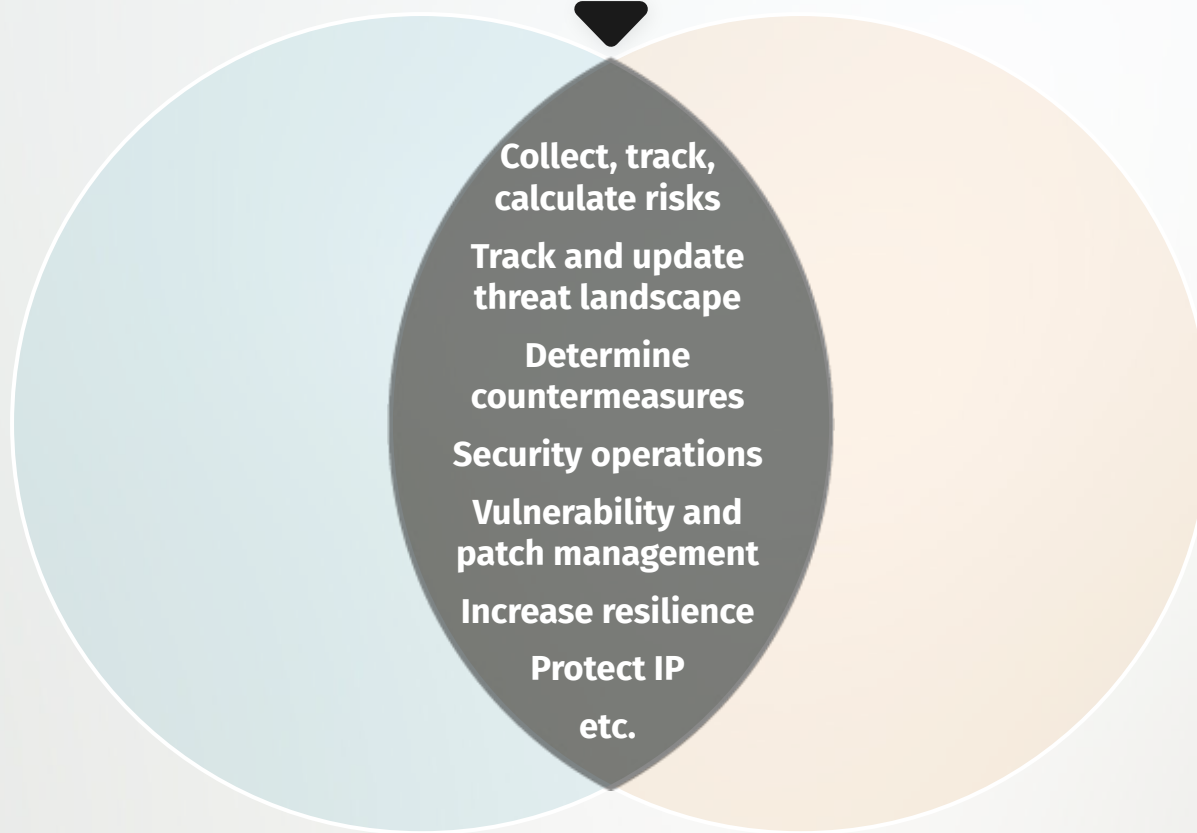
Reputational

SIMILARITIES



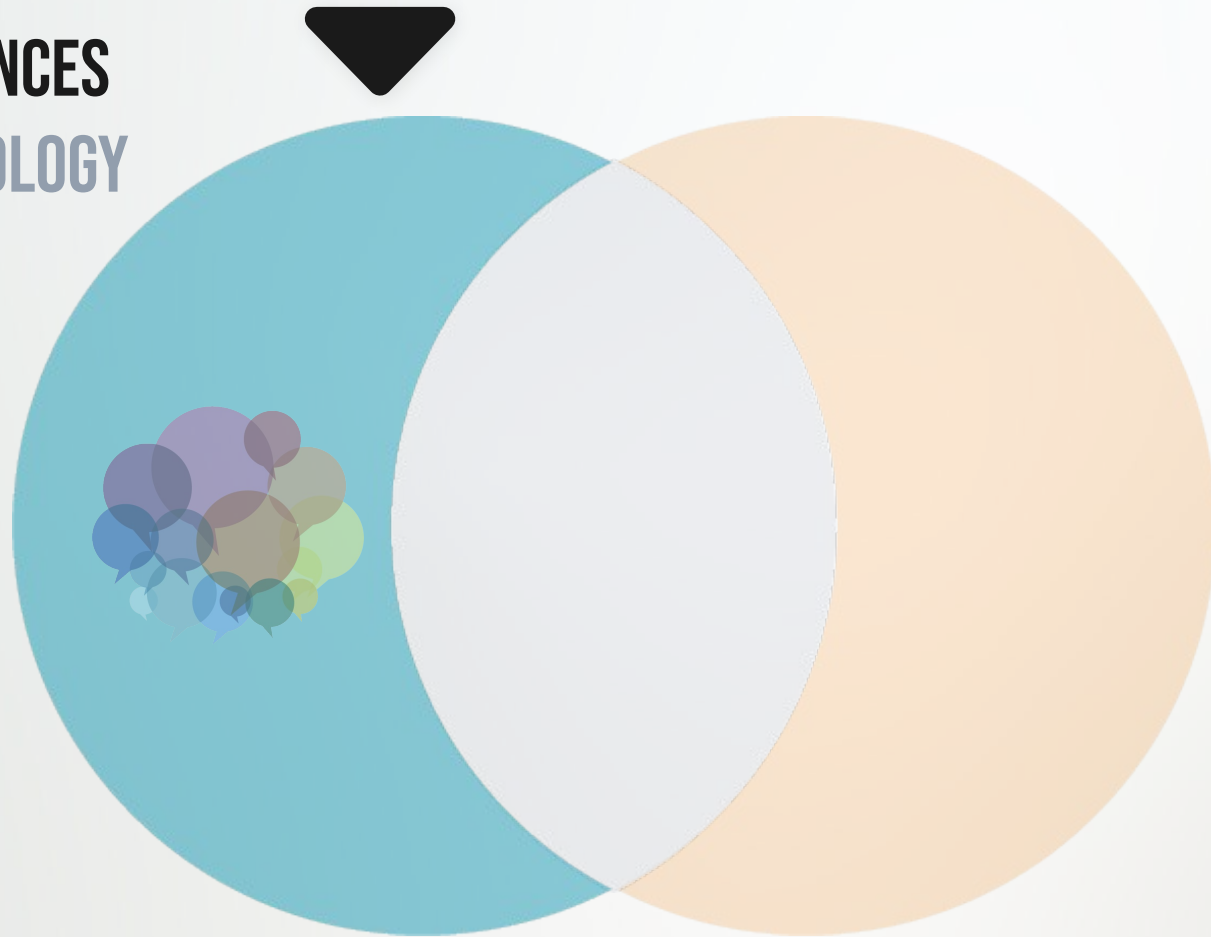
SIMILARITIES

Understand and inform organization on risk exposure



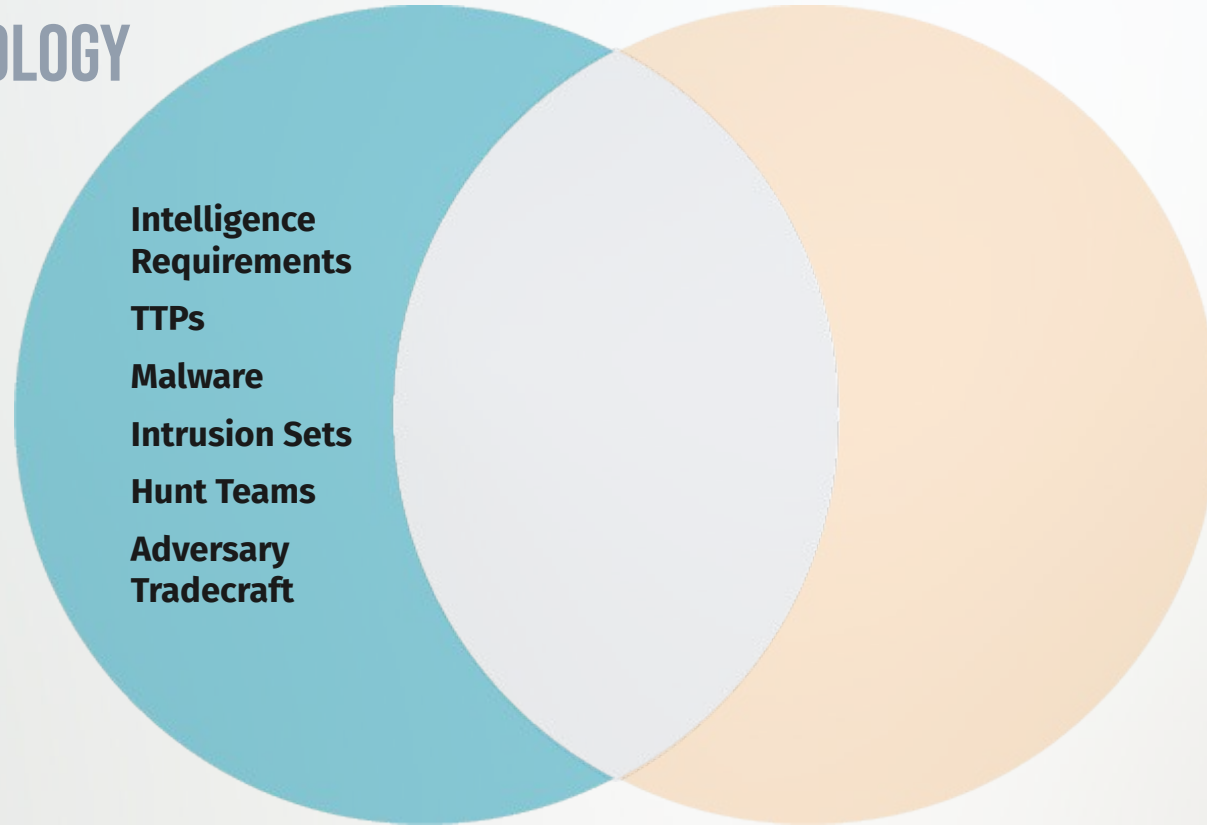
DIFFERENCES

TERMINOLOGY



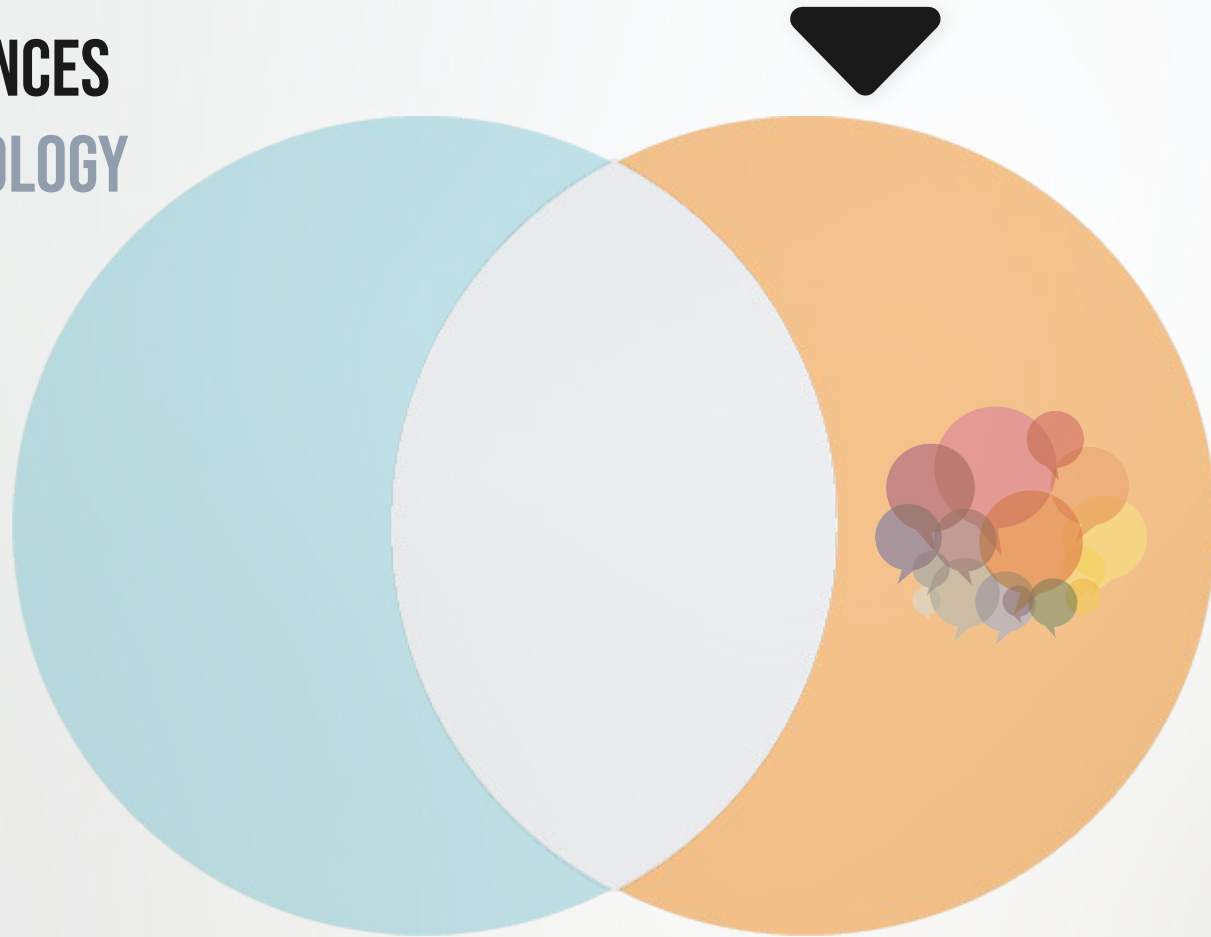
DIFFERENCES

TERMINOLOGY



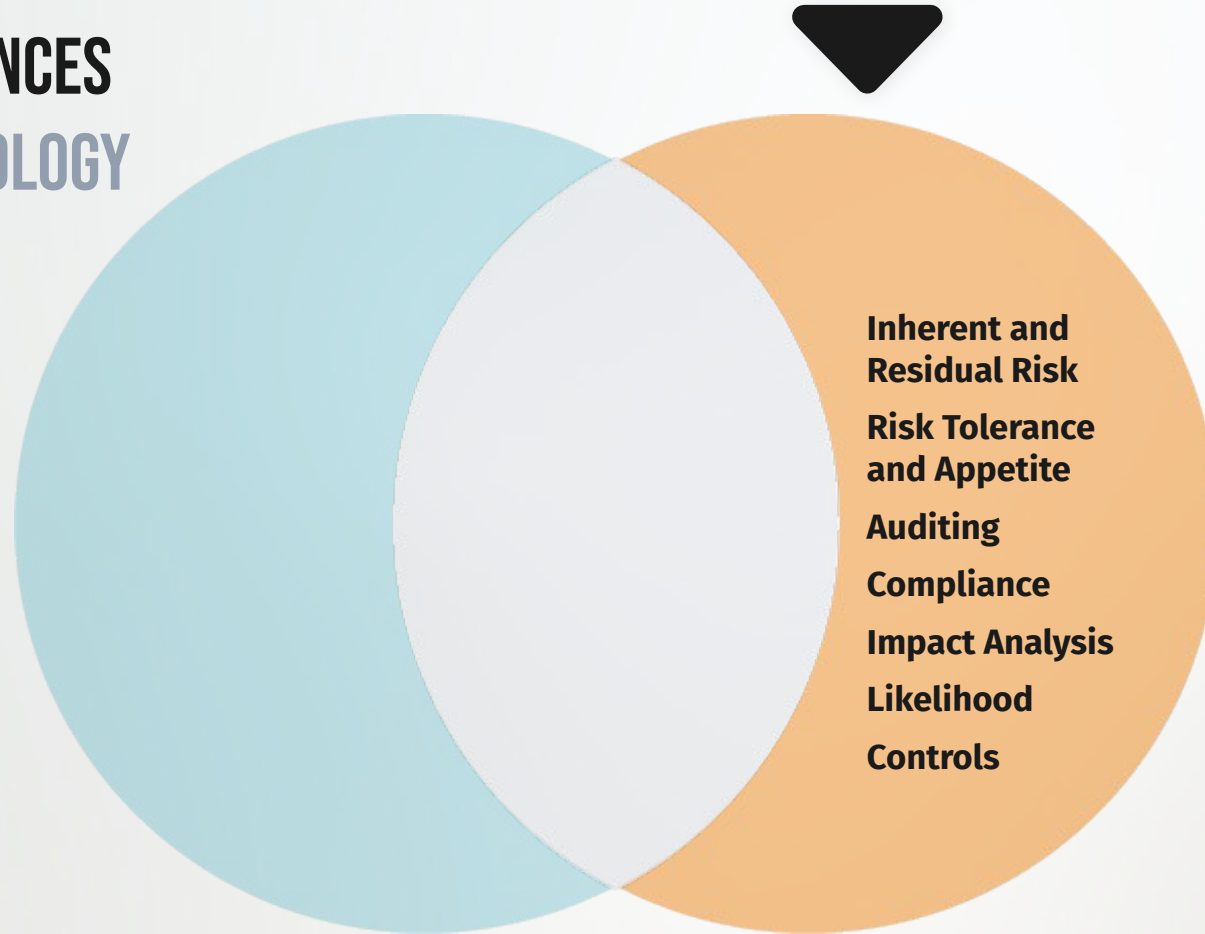
DIFFERENCES

TERMINOLOGY



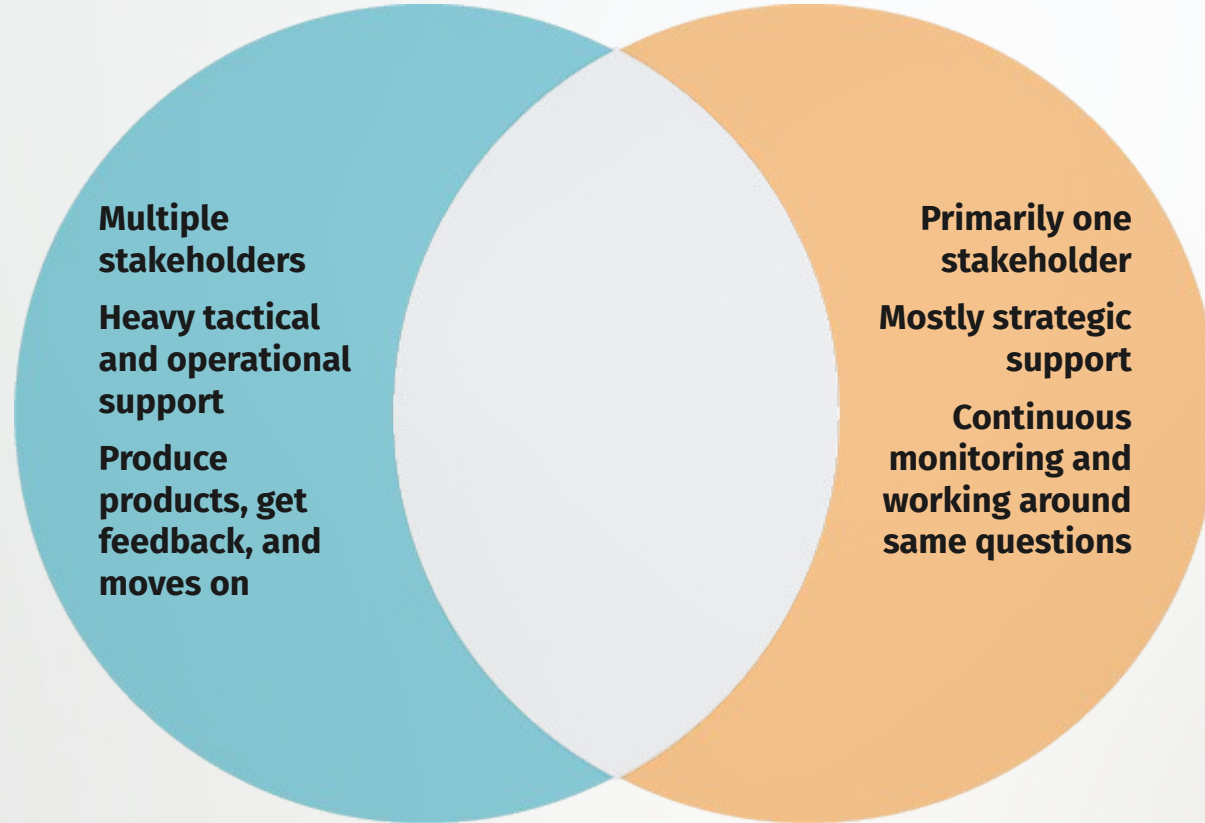
DIFFERENCES

TERMINOLOGY



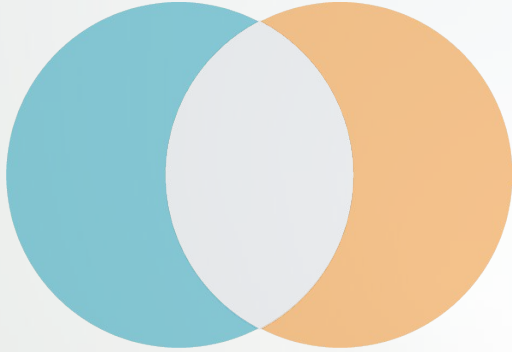
DIFFERENCES

OPS

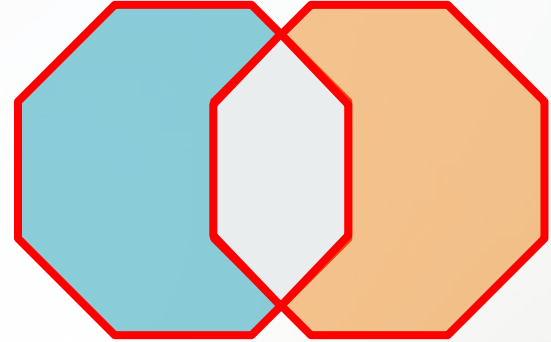


CHALLENGES

When did



lead to



?



WHAT?

WHO?

WHY?

DISCUSSION

- 1 ? What have your experiences been in integrating CTI and cyber risk?
- 2 ? What challenges have you experienced during this process?

CHALLENGES



CULTURE



STAKEHOLDERS



EXPECTATIONS

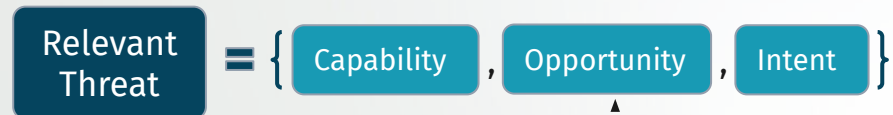


PROCESSES/INTERACTION

...AND YET...

The shared goal is risk reduction.

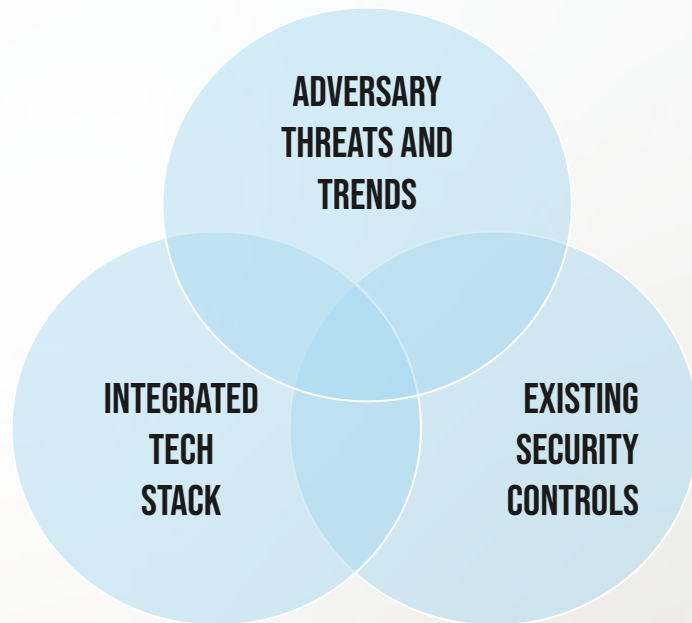
Threats are an input into overall risk.



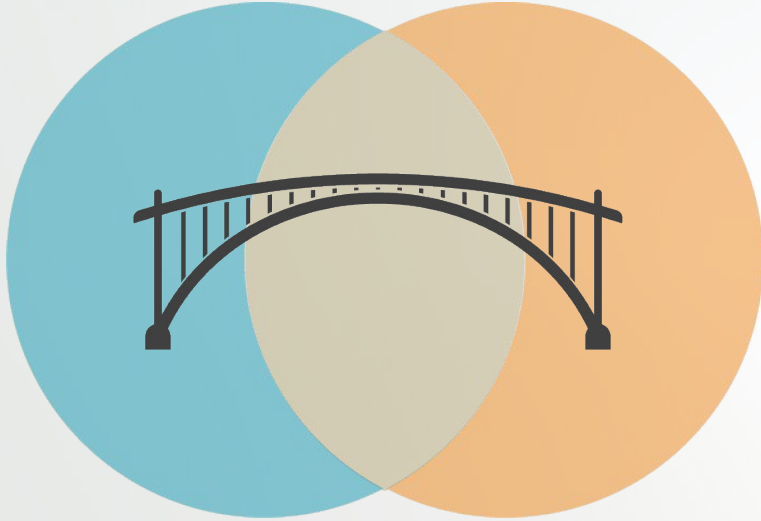
Organisations can only control **1** of these variables, but...

a reduction in any of the three drives down overall threat and provides a more scoped focus for risk management decisions

CYBER RISK



BRIDGING THE GAP



BUILD MUTUAL UNDERSTANDING



APPLY CROSS-FUNCTIONAL CONCEPTS



CREATE COLLABORATIVE WORKFLOWS

CHAPTER 3: WE ROCK HARDER TOGETHER

Ft. Gandalf on Drums

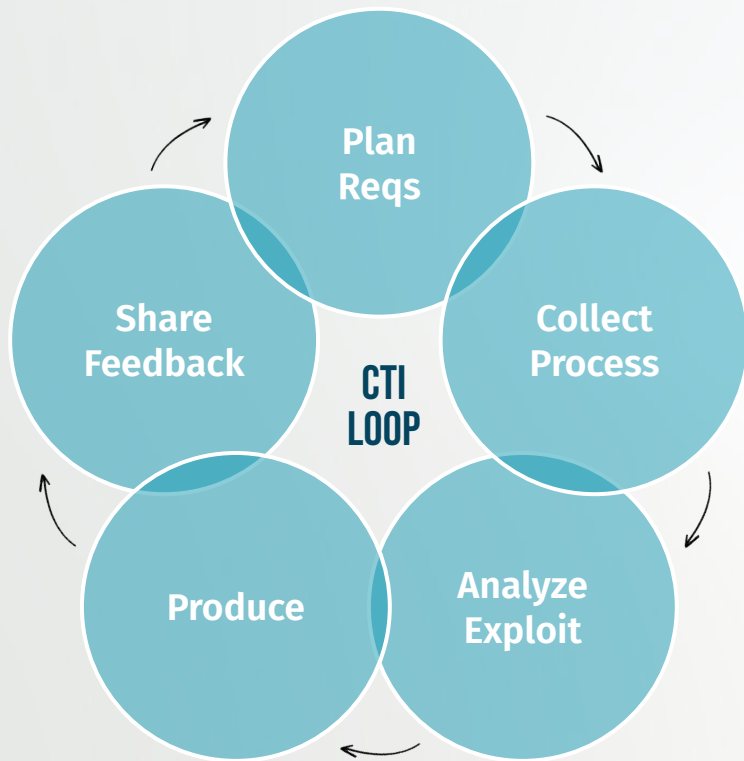


ALIGN



**INTRODUCE AND APPLY
ELEMENTS OF CTI TO RISK.
BECOME *FRICTIONLESS*.**

PROCESSES (SEPARATE)



PROCESSES (ALIGNED)

PLAN

COLLECT

ANALYZE

PRODUCE

SHARE/FEEDBACK



PLAN

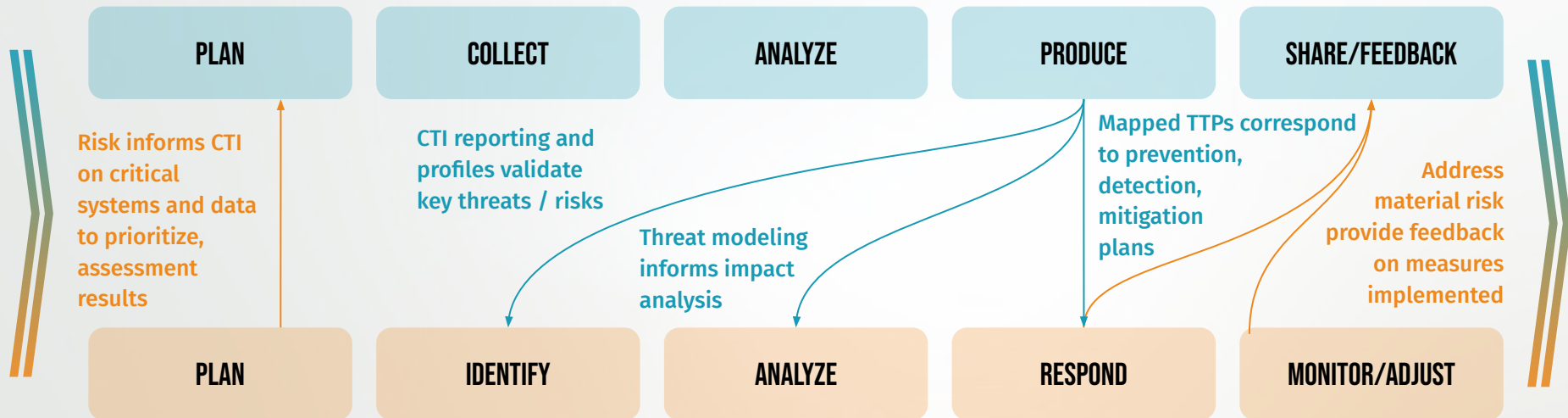
IDENTIFY

ANALYZE

RESPOND

MONITOR/ADJUST

PROCESSES (ALIGNED)



Understand the threats associated with the industry and to the organization, taking informed decisions as appropriate to the risk posed to the organization.

CTI FRAMEWORKS

OODA LOOP

Act

Execute decision
in a timely
manner

Decide

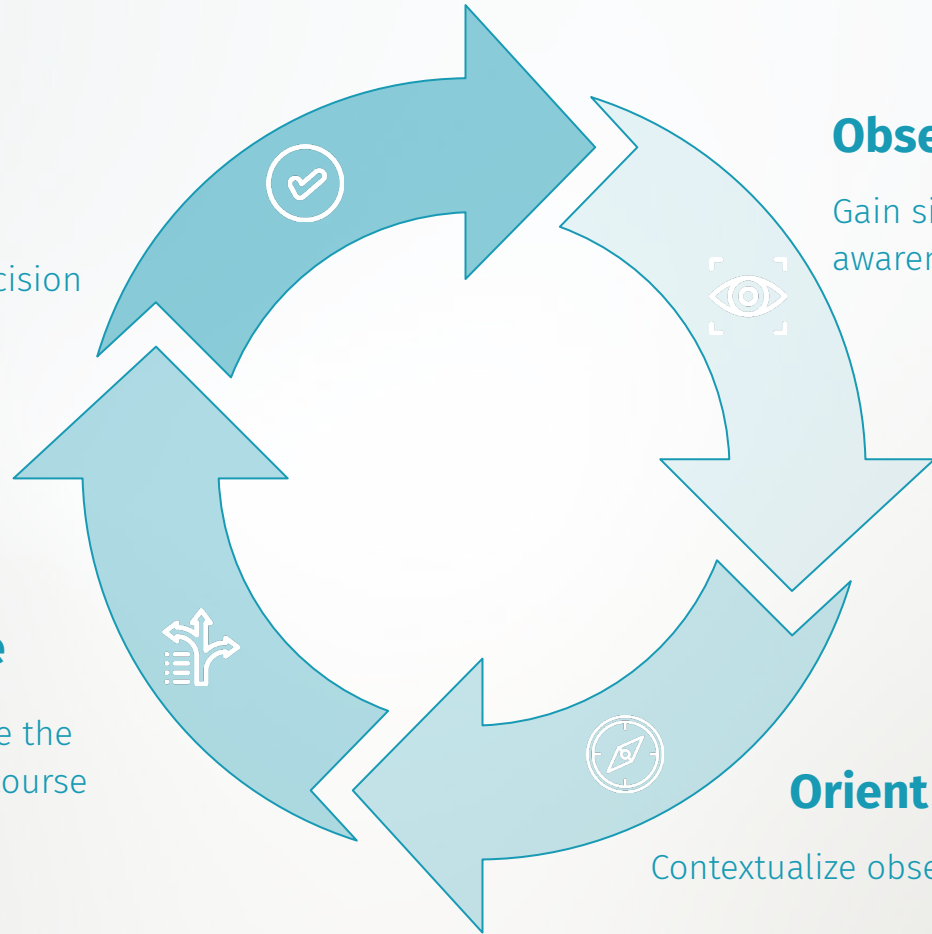
Formulate the
optimal course
of action

Observe

Gain situational
awareness

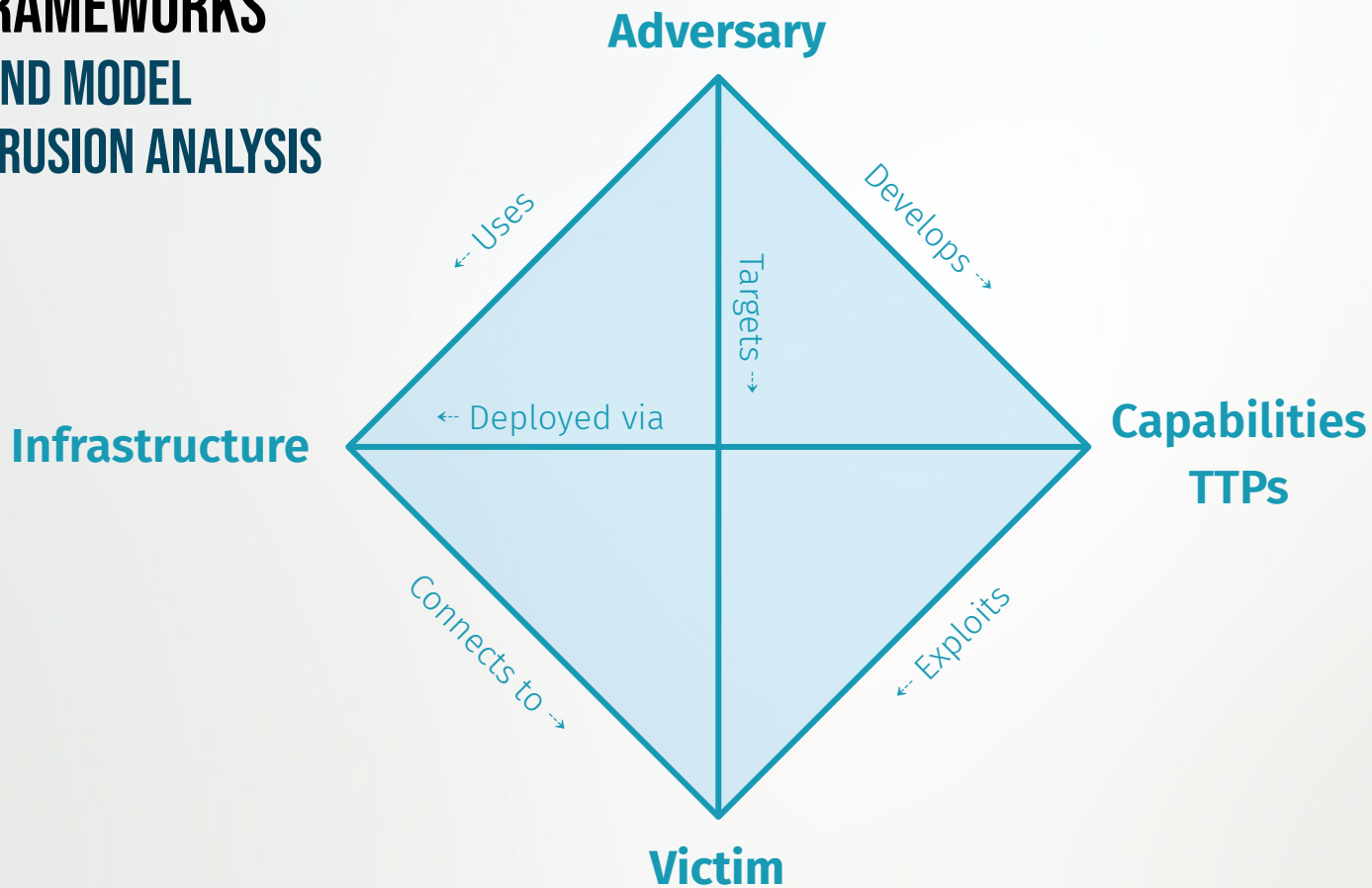
Orient

Contextualize observations



CTI FRAMEWORKS

DIAMOND MODEL OF INTRUSION ANALYSIS

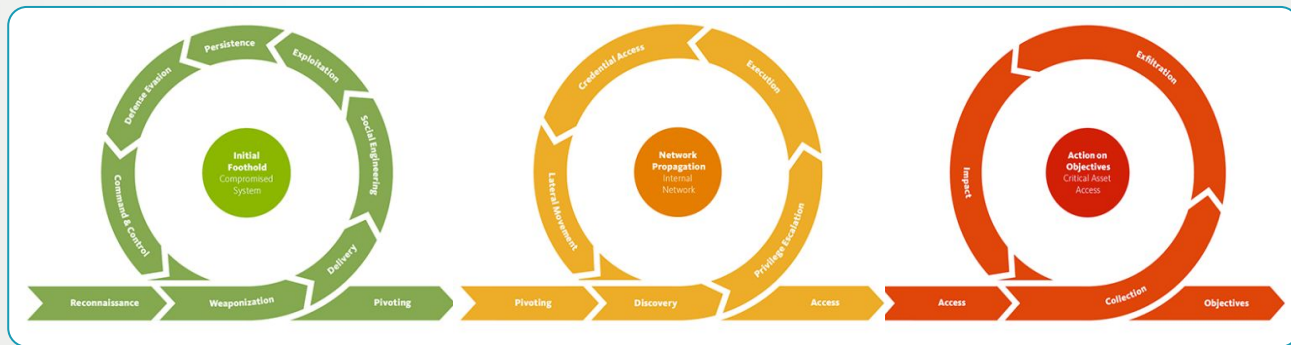
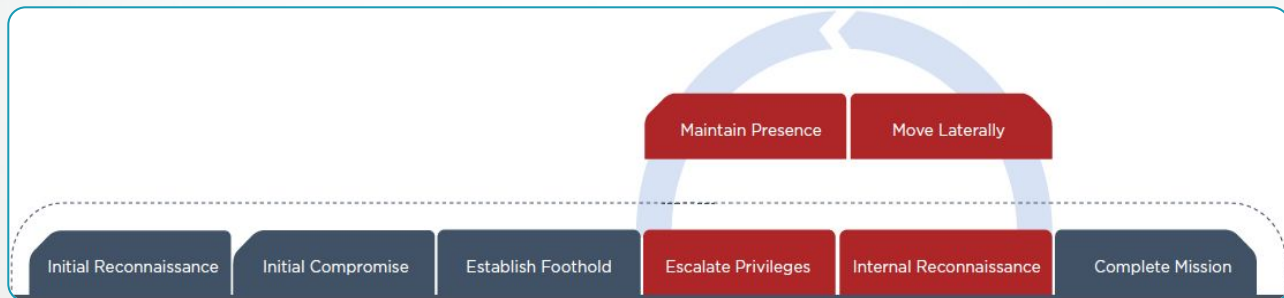


ATT&CK®

Initial Access	Execution	Persistence	Privilege Escalation	Defense Evasion	Credential Access	Discovery	Lateral Movement	Collection	Command And Control	Exfiltration	Impact
11 items	27 items	42 items	21 items	57 items	16 items	22 items	15 items	13 items	21 items	9 items	14 items
Supply Chain Compromise	Control Panel Items	Security Support Provider	Access Token Manipulation	Access Token Manipulation	Input Capture	Password Policy Discovery	Logon Scripts	Input Capture	Domain Fronting	Data Compressed	Endpoint Denial of Service
	Service Execution				Credential Dumping	Process Discovery	Pass the Hash	Data from Network Shared Drive	Uncommonly Used Port	Data Encrypted	
Drive-by Compromise	PowerShell	AppCert DLLs	Extra Window Memory Injection	Control Panel Items		Metadata System	Application Deployment Software				
Spearphishing Attachment	Regsvr32	Logon Scripts		Extra Window Memory Injection	Credentials in Registry	Applicable to: client endpoints			Remote Access Tools	Exfiltration Over	Network Denial of Service
	Rundll32	Image File Execution Options Injection	Process Injection	Masquerading	LLMNR/NBT-NS	Detection score: 4		Email Collection	Commonly Used Port	Command and Control Channel	Data Encrypted for Impact
Exploit Public-Facing Application	Scripting		AppCert DLLs	Process Injection	Poisoning and Relay	System Owner/User Discovery	Component Object Model	Audio Capture			
	Scheduled Task	Application Shimming	Image File Execution Options	Regsvr32	Account Manipulation	Account Discovery	Exploitation of Remote Services	Automated Collection	Data Obfuscation	Automated Exfiltration	Data Destruction
External Remote Services	User Execution	Scheduled Task	Image File Execution Options	Rundll32		Process Discovery		Clipboard Data	Standard Application Layer Protocol		Defacement
	CMSTP	Accessibility Features	Application Shimming	Image File Execution Options Injection	Credentials in Files	System Network Configuration Discovery	Pass the Ticket	Data from Information Repositories	Communication Through Removable Media	Data Transfer Size Limits	Disk Content Wipe
Hardware Additions	Command-Line Interface	Account Manipulation	Scheduled Task	Timestamp	Exploitation for Credential Access	Application Window Discovery	Remote Desktop Protocol	Data from Local System	Connection Proxy		Disk Structure Wipe
Replication Through Removable Media	Compiled HTML File	Applnit DLLs	Accessability Features	Binary Padding	Forced Authentication	Browser Bookmark Discovery	Remote File Copy	Data from Removable Media	Custom Command and Control		Firmware Corruption
Spearphishing Link	Execution through API	BITS Jobs	Applnit DLLs	BITS Jobs	Hooking	File and Directory Discovery	Remote Services	Data Staged	Crypt Protocol	Legend	
Spearphishing via Service	Execution through Module Load	Bootkit	Bypass User Account Control	Bypass User Account Control	Input Prompt	Network Service Scanning	Replication Through Removable Media	Man in the Browser	Data	Technical reference for 1 group	
Trusted Relationship	Exploitation for Client Execution	Browser Extensions	DLL Search Order Hijacking	CMSTP	Network Sniffing	Network Share Discovery		Screen Capture	Domain Generation Algorithm	Technical reference for 1 groups	
Valid Accounts	Graphical User Interface	Change Default File Association	Exploitation for Privilege Escalation	Code Signing	Password Filter DLL	Network Sniffing	Shared Webroot	Video Capture		Technical in group + detection	
	InstallUtil	Component Firmware		Compile After Delivery	Private Keys	Peripheral Device Discovery	Taint Shared Content			Technical in detection	

CTI FRAMEWORKS

KILL CHAINS



RISK MANAGEMENT FRAMEWORKS

NIST's Risk Management Framework (RMF):



- Essential activities **prepare** the organization to manage security and privacy risks.
- **Categorize** the system and information processed, stored, and transmitted based on an impact analysis.
- **Select** the set of NIST SP 800-53 controls to protect the system based on risk assessment(s).
- **Implement** the controls and document how controls are deployed.
- **Assess** to determine if the controls are in place, operating as intended, and producing the desired results.
- Senior official makes a risk-based decision to **authorize** the system (to operate).
- Continuously **monitor** control implementation and risks to the system.

RISK MANAGEMENT FRAMEWORKS

NIST [Risk Framework Profiles](#)

- The [Manufacturing Industry Profile](#) provides an overview of business drivers and Industrial Control System (ICS) considerations.
- The [Ransomware Risk Management profile](#) provides a fulsome dissection and guidance across all of the 5 NIST CSF functions.
- The [Election Infrastructure Profile](#) is draft—and as a result several times the size of the others—and a good illustration of how the sausage is made.

Examples of Framework Profiles

The Framework Profile (“Profile”) is the alignment of the Functions, Categories, and Subcategories with the business requirements, risk tolerance, and resources of the organization. A Profile enables organizations to establish a roadmap for reducing cybersecurity risk that is well aligned with organizational and sector goals, considers legal/regulatory requirements and industry best practices, and reflects risk management priorities. Given the complexity of many organizations, they may choose to have multiple profiles, aligned with particular components and recognizing their individual needs.

Framework Profiles can be used to describe the current state or the desired target state of specific cybersecurity activities. The Current Profile indicates the cybersecurity outcomes that are currently being achieved. The Target Profile indicates the outcomes needed to achieve the desired cybersecurity risk management goals. Profiles support business/mission requirements and aid in communicating risk within and between organizations. This Framework does not prescribe Profile templates, allowing for flexibility in implementation.

Comparison of Profiles (e.g., the Current Profile and Target Profile) may reveal gaps to be addressed to meet cybersecurity risk management objectives. An action plan to address these gaps to fulfill a given Category or Subcategory can contribute to the roadmap described above. Prioritizing the mitigation of gaps is driven by the organization’s business needs and risk management processes. This risk-based approach enables an organization to gauge the resources needed (e.g., staffing, funding) to achieve cybersecurity goals in a cost-effective, prioritized manner. Furthermore, the Framework is a risk-based approach where the applicability and fulfillment of a given Subcategory is subject to the Profile’s scope.

- [NISTIR 8183](#) - Cybersecurity Framework Manufacturing Profile
- [NISTIR 8374](#) - Ransomware Risk Management: A Cybersecurity Framework Profile
- [NISTIR 8183r1](#) - Cybersecurity Framework Version 1.1 Manufacturing Profile Rev. 1
- [NISTIR 8310 \(Draft\)](#) - Cybersecurity Framework Election Infrastructure Profile
- [NIST IR 8323 Revision 1](#) - Foundational PNT Profile: Applying the Cybersecurity Framework for the Responsible Use of PNT Services
- [NIST TN 2051](#) - Cybersecurity Framework Smart Grid Profile
- [White Paper NIST CSWP 27 \(Draft\)](#) | Cybersecurity Profile for Hybrid Satellite Networks (HSN) Final Annotated Outline

RISK MANAGEMENT FRAMEWORKS

Risk = Likelihood x Impact

Risk also = Threat x Vulnerability x Impact

IMPACT	Catastrophic (5)	5	10	15	20	25
	Significant (4)	4	8	12	16	20
	Moderate (3)	3	6	9	12	15
	Low (2)	2	4	6	8	10
	Negligible (1)	1	2	3	4	5
		Improbable (1)	Remote (2)	Occasional (3)	Probable (4)	Frequent (5)
		LIKELIHOOD				



CYBER-RISK INTEGRATED FRAMEWORKS

Factor Analysis of Information Risk (FAIR) Cyber Risk Quantification Model



CYBER-RISK INTEGRATED FRAMEWORKS

The Vocabulary for Event Recording and Incident Sharing (VERIS)

Describes security incidents in a structured and repeatable manner.

- A set of metrics
- A common language

4 Attributes:

- Actors
- Actions
- Attributes
- Assets

ACTORS

Variable	Question
actor.external	Was there an external threat actor?
actor.internal	Was there an internal threat actor?
actor.partner	Was there a partner threat actor?
actor.unknown	Was there a threat actor but you don't know what kind?

ACTIONS

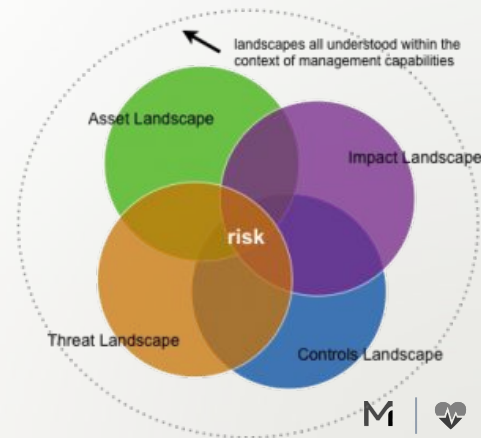
Variable	Question
action.hacking	Was there evidence of hacking?
action.malware	Was there evidence of malware?
action.social	Was there evidence of social engineering?
action.misuse	Was there evidence of misuse of privileges?
action.error	Was there an error that lead to the incident?
action.physical	Was there evidence of physical attack?
action.environmental	Was there an act of God that lead to the incident?
action.unknown	Are we unsure what happened?

ATTRIBUTES

Variable	Question
attribute.confidentiality	Is it possible that confidential information was exposed?
attribute.integrity	Was the integrity of any system affected?
attribute.availability	Was there an availability loss?
attribute.unknown	Are we unsure what was affected?

ASSET

Variable	Question
asset.assets.server	Was a server affected by the incident?
asset.assets.network	Was a network device affected?
asset.assets.user	Were any end-user devices affected?
asset.assets.terminal	Were any terminal devices affected (e.g. ATM, Kiosk, etc)?
asset.assets.media	Did the incident affect any paper documents, or storage media?
asset.assets.people	Were any people compromised (e.g. Social Engineering)?
asset.assets.unknown	Are we unsure what was affected?



CYBER-RISK INTEGRATED FRAMEWORKS

OWASP's Risk Rating Methodology

- Step 1: Identify Risks
- Step 2: Estimate Likelihood
- Step 3: Estimate Impacts
- Step 4: Calculate Risk Severity Rating

Overall Risk Severity				
Impact	HIGH	Medium	High	Critical
	MEDIUM	Low	Medium	High
	LOW	Note	Low	Medium
		LOW	MEDIUM	HIGH
	Likelihood			



Technical Impact				Business Impact			
<i>Confidentiality</i>	<i>Integrity</i>	<i>Availability</i>	<i>Accountability</i>	<i>Financial Damage</i>	<i>Brand Damage</i>	<i>Non-Compliance</i>	<i>Privacy</i>
5	2	2	1	4	2	6	3
Technical Impact = 2.5				Business Impact = 3.75			

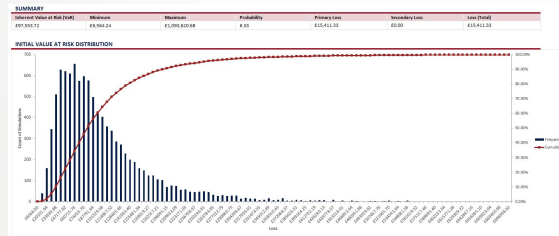
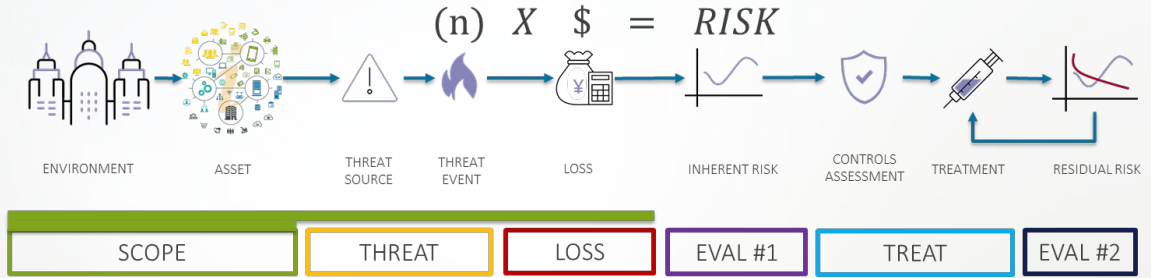


Likelihood and Impact Levels	
0 to <3	LOW
3 to <6	MEDIUM
6 to 9	HIGH

Threat Agent Factors				Vulnerability Factors			
<i>Skill Level</i>	<i>Motivation</i>	<i>Opportunity</i>	<i>Size</i>	<i>Ease of Discovery</i>	<i>Ease of Exploitation</i>	<i>Awareness</i>	<i>Detectability</i>
3	3	4	1	9	9	1	1
Overall likelihood = 3.875							

CYBER-RISK INTEGRATED FRAMEWORKS

ISF Quantitative Techniques in Information Risk Analysis



[Blog](#)

HOW THIS GETS TRACKED INTERNALLY

NOTIONAL RISK REGISTER



#	BUSINESS RISK	RISK CATEGORY	LIKELIHOOD	IMPACT	INHERENT RISK	CONTROLS	RESIDUAL RISK	OVERALL RISK	BUSINESS AREAS
1	Data center outage	Operational	Possible	Extreme	15	Ineffective	12	Very High	IT, Board, Data Protection, Ext. Audit, Emerging Risk, Earnings
2	Interest rates rise on variable debt	Financial	Possible	Major	12	None	12	Medium	Board, Treasury, Finance, Legal
3	Supplier risk - component supply	Operational	Likely	Major	16	Ineffective	12	Medium	Manufacturing, Earnings, Board
4	Opp - changing customer preferences leading to decrease in market size	Strategic	Near Certain	Major	20	Ineffective	15	Low	Emerging Risk, Board

YOUR RISK REGISTER



RANK	BUSINESS RISK	RISK CATEGORY	LIKELIHOOD	IMPACT	INHERENT RISK	CONTROLS	RESIDUAL RISK	OVERALL RISK	BUSINESS AREAS
1									
2									
3									
4									

AUDIENCES & COMMUNICATIONS

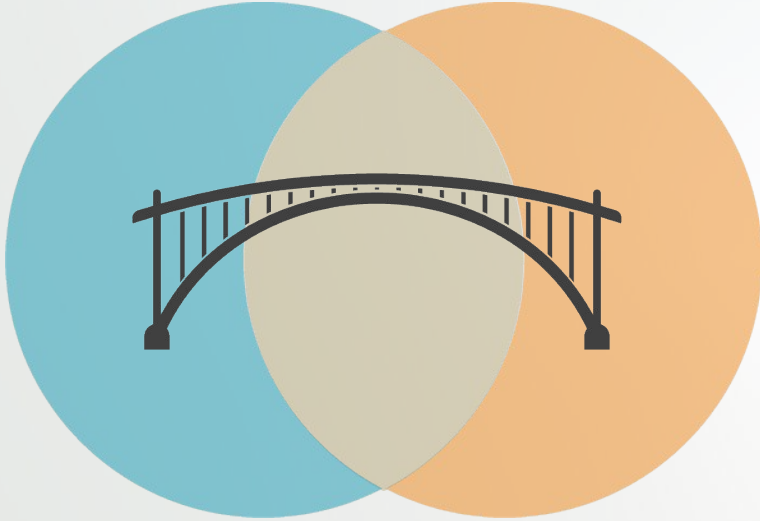
AUDIENCE	STRATEGIC	OPERATIONAL	TACTICAL
Security Roles	Chief Executive Officer Chief Information Security Officer Security Management Risk Management	Incident Response Team Forensics Team Red Team / Pentesting Purple Team	Security Operations Center Network Operations Center Vulnerability Management
Tasks	Allocate resources Communicate with executives	Determine attack vectors Remediation Hunt for breaches	Indicators to security tools Patch systems Monitor, escalate alerts (triage)
Problems	No clear investment priorities Executives are not technical	Resource intensive event reconstruction Difficult to identify, quantify damage	False positives Difficult to prioritize patches Alert overload
Value of CTI	Demystify threats Prioritize based on risk	Add context to reconstruction Focus in on potential targets	Validate and prioritize: - Indicators - Patches - Alerts

DISCUSSION

? What areas of alignment would be most impactful in your org?

? Where are you currently already supporting risk frameworks?

UP NEXT



RISK STAKEHOLDER ANALYSIS



RISK INTELLIGENCE REQUIREMENTS



RISK-FOCUSED THREAT MODELING



THREAT PROFILING FOR RISK



RESPONSIBILITY ASSIGNMENT



RISK-ADJUSTED VULN MANAGEMENT

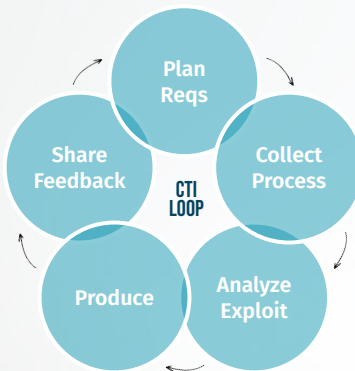
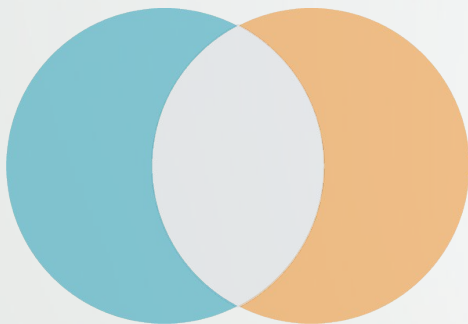
LUNCH BREAK - 1 HR



WELCOME BACK



RECAP AT A GLANCE



- Diamond Model
- MITRE ATT&CK
- Kill Chains
- NIST RMF
- FAIR
- Heatmap

#	BUSINESS RISK	RISK CATEGORY	LIKELIHOOD	IMPACT	INHERENT RISK	CONTROLS	RESIDUAL RISK	OVERALL RISK	BUSINESS AREAS
1	Data center outage	Operational	Possible	Extreme	15	Ineffective	12	Very High	IT, Board, Data Protection, Ext. Audit, Emerging Risk, Earnings
2	Interest rates rise on variable debt	Financial	Possible	Major	12	None	12	Medium	Board, Treasury, Finance, Legal
3	Supplier risk - component supply	Operational	Likely	Major	16	Ineffective	12	Medium	Manufacturing, Earnings, Board
4	Opp - changing customer preferences leading to decrease in market size	Strategic	Near Certain	Major	20	Ineffective	15	Low	Emerging Risk, Board

CHAPTER 4: WE'RE ALL PART OF THE PROBLEM

Ft. Gimli on Bass



ENABLE



TEAMWORK

This job would have taken a lifetime. Now it will take two.



TEAMWORK

Large ambitious goals usually require that people work together.

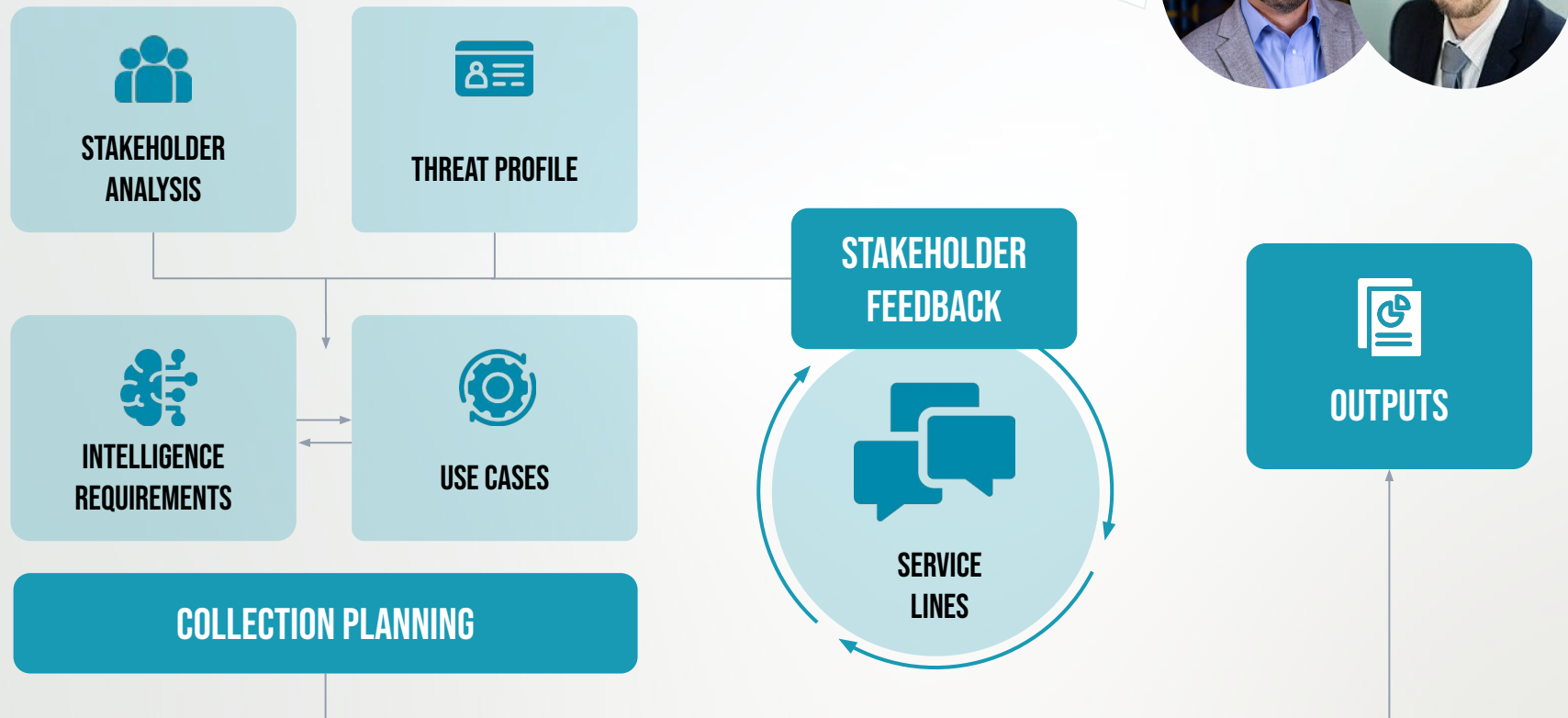


**REINFORCE COLLABORATIVE
WORKFLOWS WITH
EXAMPLES AND TOOLS.**

Laughs in British



STAKEHOLDER ANALYSIS



Stakeholder Engagement

— What have we done?

Process

- › Three key roles
- › Semi-structured Interviews

Goals - NFCERT

- › Stakeholders' «problem/needs»
- › How we can provide/increase value

Goals Member

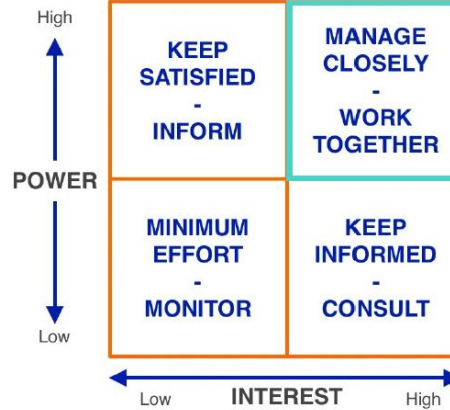
- › Increase visibility
- › Their needs
- › How NFCERT can support

-> Metrics = SHOWING VALUE

Nordi

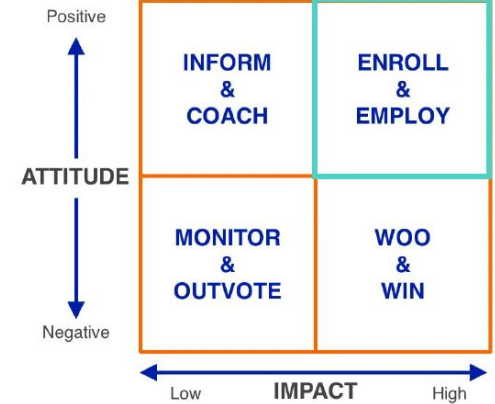


Stakeholder Matrix



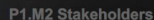
The 'Standard' Stakeholder Map

Reproduced from The Influence Agenda
by Dr Mike Clayton (Palgrave Macmillan)



Stakeholder Triage

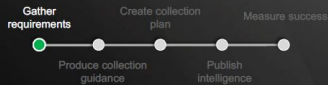
Reproduced from The Influence Agenda
by Dr Mike Clayton (Palgrave Macmillan)



INTERVIEW FORM

- Basic info
- What are you most concerned about?
- What do you need from us and why do you need it?
- How will you use it?
- How will you communicate with us? (RFIs)
- How can we reliably receive feedback from you?

Remember: Rapport is important. SOC analysts like coffee too.

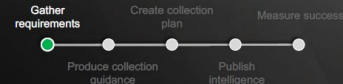
[illegible]

Apply our workshop



P1.M2 Stakeholders

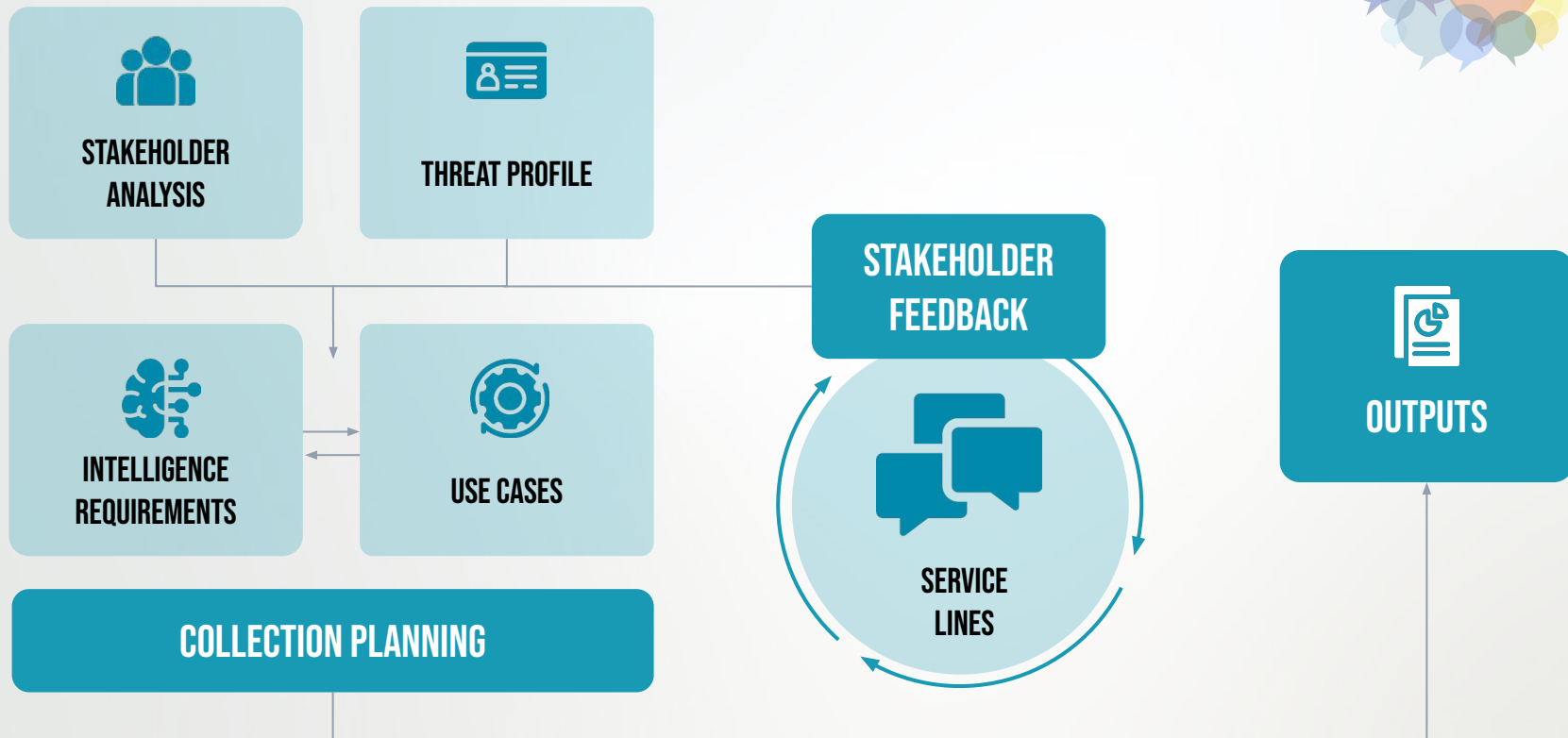
MASTER LIST

[illegible]

"SOFT SKILLS"

SO HOT RIGHT NOW

WHERE/HOW ARE YOU CURRENTLY ENGAGING RISK?



DISCUSSION

- ❓ Does CTI in your organisation engage with risk management as a stakeholder?
- ❓ How could better stakeholder collaboration be fostered?

INTELLIGENCE REQUIREMENTS

- Consider these as a knowledge capture on stakeholder use cases and intelligence needs.



See you later

- The CTI team...
 - Translates the needs to intelligence requirement
 - Add a priority rating
 - Establishes SLAs
 - Documents intended output
- Additional resources:
 - Mandiant's ["A Requirements-Driven Approach to Cyber Threat Intelligence"](#)
 - [Intel471's General Intelligence Requirements \(GIR\) Handbook](#) (pt. 1)
 - [Intel471's General Intelligence Requirements \(GIR\) Handbook](#) (pt. 2)
 - [Red Hat's Guide to Developing Priority Intelligence Requirements \(PIRs\)](#)

Intelligence Requirement	
PRIORITY:	1 / HIGH - Less than X days 2 / MED - Less than X days 3 / LOW - Less than X days
CATEGORY:	Adversary TTPs Threat Actor Tracking Service Availability
FOCUS:	CTI analysts will leverage external sources to perform tactical and trend analysis regarding new malware development or evolution (weaponization). Analytic focus will be on identification of TTPs and curation of high value indicators of compromise.
EXPECTED OUTCOME:	Resulting product output will be used to guide Cyber Security Operations' monitoring, detection, and response functions.

Requirement	Status	Priority Level	Last Updated	Primary Stakeholder(s)	Reporting Intent	Intel Product Output(s)
The CTI Team will monitor for cyber threat groups attempting to compromise <organization> or its industry peers	Active	1	June 2022	Risk Management Senior Leadership CIRT	Situational Awareness	Monthly Threat Report
The CTI Team will capture Tactics, Techniques, and Procedures (TTPs) for groups targeting industry peers	Active	1	June 2022	CIRT SOC Purple Team	Situational Awareness Hunting	Adversary Playbook Threat Hunting Guide
The CTI Team will prioritize cyber threat groups and trends based on understanding critical business systems, individuals, and client data	Active	2	June 2022	Risk Management Senior Leadership	Risk Impact Assessments	Annual Cyber Threat Trends Report
The CTI team will monitor for newly discovered vulnerabilities and adversary groups exploiting them	Inactive	3	Jan 2022	Vulnerability Management	Situational awareness Patch Prioritization	Vulnerability Dashboard

WHEN CTI ANALYSTS

**REALISE THEY'RE
NOT THE MAIN CHARACTER**



P1.M1 Introduction

GIRH EXPLAINED

5 component parts to a GIR category:

1. Typical Stakeholders
2. Common Use Cases
3. Parent GIR entry
4. Essential Elements of Information (EEI)
5. Child GIR entries

Apply our workshop



ANATOMY OF THE CU-GIR

Intelligence consumers typically interested in this GIR category

GIR 2: VULNERABILITIES AND EXPLOITS

1

TYPICAL STAKEHOLDERS

- Security Operations
- Blue Team
- Red Team
- Incident Response
- Forensics
- Vulnerability/Patch Management

COMMON USE CASES 2

- Vulnerability identification and patching
- Exploit and pen testing

GIRS

3

2.1 Vulnerabilities

- Determine capability and intent of adversaries discussing and sharing vulnerabilities.
 - Reputation, influence and credibility.
 - Communication modes and identifiers.
 - Level and nature of interest.
- Identify characteristics of vulnerabilities discussed and shared by actors.
 - Capability.
 - Impact (technology and vendor).
 - Severity impact or risk.
 - Exploit status, such as proof of concept (PoC), weaponized or productized.
 - Patch or mitigation availability.

2.1.1 Operating system (OS) vulnerabilities

2.1.1.1 Desktop and server OS vulnerabilities

2.1.1.2 Mobile OS vulnerabilities

2.1.2 Software and web application vulnerabilities

2.1.2.1 Web browser vulnerabilities

Parent GIR category

GIR subcategory; inherits parent attributes and EEIs

Typical use cases supported by this GIR

Essential Elements of Information (EEIs) for each GIR parent category and subcategories; each EEI can be used as specific intelligence requirement that informs stakeholder

Intelligence Requirement	
PRIORITY:	1 / HIGH - Less than X days 2 / MED - Less than X days 3 / LOW - Less than X days
CATEGORY:	Adversary TTPs Threat Actor Tracking Service Availability
FOCUS:	CTI analysts will leverage external sources to perform tactical and trend analysis regarding new malware development or evolution (weaponization). Analytic focus will be on identification of TTPs and curation of high value indicators of compromise.
EXPECTED OUTCOME:	Resulting product output will be used to guide Cyber Security Operations' monitoring, detection, and response functions.

MANDIANT CTI POLICE

**CTI TEAM USING
DIFFERENT INTEL
REQUIREMENT FRAMEWORK**

ORGANISING MULTIPLE INTELLIGENCE REQUIREMENTS

Categorizing individual requirements guides the design and research process, organising all intelligence requirements collectively to define broader prioritisation and communication to stakeholders.

This **fosters a more strategic approach** with **clear prioritisation** and **synchronized knowledge management**.

TABLE 3. An example of how multiple intelligence requirements can be categorized and organized.

Intelligence Requirement	Priority	Collection Sources	Priority Stakeholders	Intent	Primary Product Type
TRANSACTIONAL PLATFORM SERVICE & AVAILABILITY					
Information will be collected and analyzed that may indicate or identify against transactional platforms and associated service infrastructure. CTI analysts will focus on producing intelligence that can be actioned to prevent, mitigate or intermediate, or limit impact of any threat to the operation and SLA of transactional platforms.	1	External CTI Providers Cyber Security Operations Open Sources Banking Regulators Community of Interest (COI)FS-ISAC GOVCERT	Executive Leadership CIO/CISO Service of Delivery Operations Enterprise Architecture Transactional Platform Custodians	Immediate Action Preservation of SLA Public Relations and External Communication	Threat Advisory Tactical Threat Report Daily/Weekly Threat Summary Report Monthly Threat Summary Report Strategic Threat Briefing

Threat Communication Workflow

CTI Analysis & Production

STRATEGIC

- Board of Directors
- Executives
- CSO

OPERATIONAL

- Security Functions
- IT/Infrastructure
- HR/Legal

TACTICAL

- Net Operations
- SOC Operations
- Patch Management

Monthly

20201211-1

20201211-1

20201211-1

20201211-1

20201211-1

20201211-1

Threat Summary

Daily/Weekly:

20201211-1

20201211-1

20201211-1

20201211-1

20201211-1

20201211-1

Advisory Report/
Brief

AD/HOC:

20201211-1

20201211-1

20201211-1

20201211-1

20201211-1

20201211-1

20201211-1

20201211-1

20201211-1

IOC Update Alert
Summary

INTELLIGENCE REQUIREMENTS



See you
later



Strategic

- What business units are at most risk to cyber crime?
- Have our investments in security positively reduced the risk we face toward threats we are currently tracking?

Operational

- What threat activity groups are currently active in our industry?
- If FUZZYSQUIRREL breached our organization, what assets would most likely be compromised?

Tactical

- What adversary behaviors should security focus on to identify threats that are the most likely to breach our organization?
- What indicators are most relevant to search for to quickly respond to the breach that has occurred today?

EFFICIENCY?

FALSE. RUTHLESS EFFICIENCY.

SERVICE LINES

- Use cases can be grouped to create efficiencies in intelligence production.
- For example, two separate use cases may require an in-depth understanding of both adversary tactics and techniques.
- These different use cases and requirements could be combined to form part of an operational or threat knowledge service line.
- Help CTI leaders manage and delegate resources as well as avoid any unnecessary duplication of work. CTI analysts will naturally have interests or skill sets suited to particular service lines.

WORKING WITH DEVELOPING STAKEHOLDERS

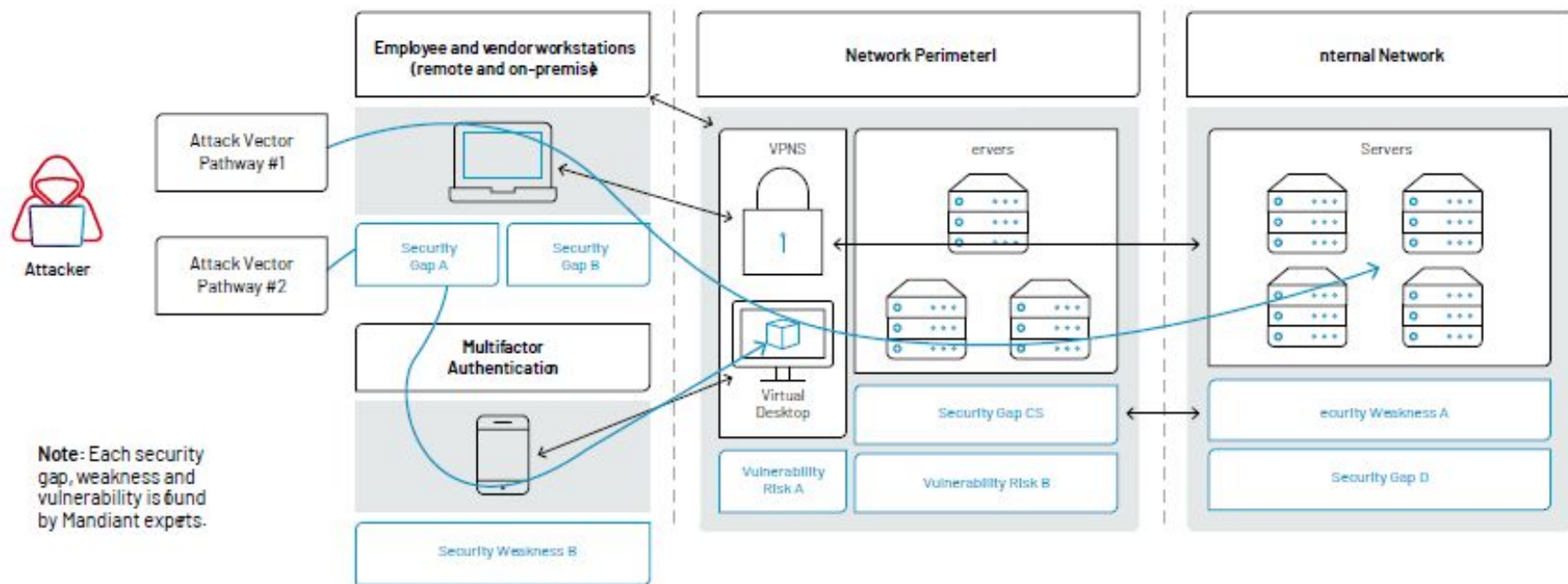
- Embrace role as an **educator**
- Don't assume **prior knowledge**
- Start **simple**
- Embrace **agility**
- Don't be afraid to **push back**



DISCUSSION

- ❓ Does your cyber risk team understand CTI enough to understand its value to risk management processes?
- ❓ Can your cyber risk team articulate their intelligence requirements?

THREAT MODELING



THREAT PROFILE

Relevant Threat = {Capability, Intent, Opportunity}

As organizations, we cannot control adversary capabilities or intent...

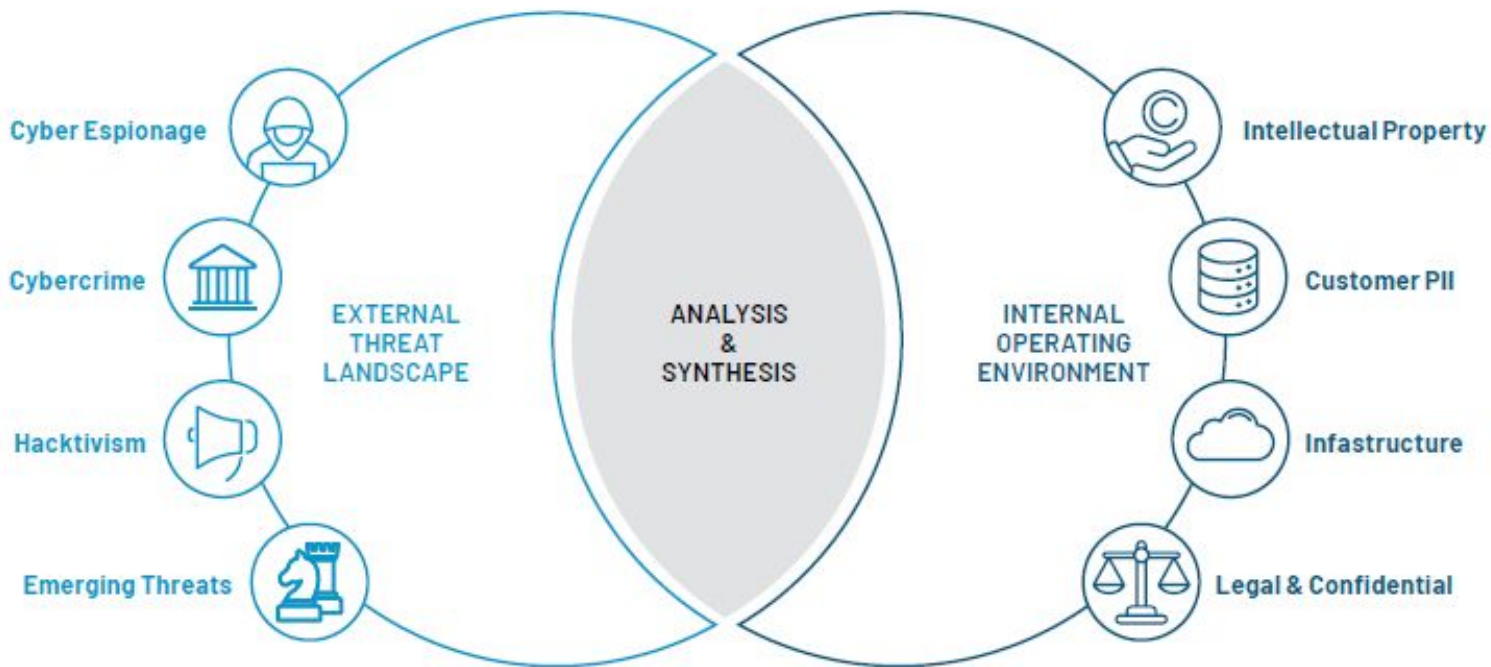
We can, however, **reduce the attack surface** (risk exposure/window of opportunity)

This includes prioritizing patching decisions.



THREAT PROFILE

“If these threats were to successfully target or infiltrate me, which ones have the potential to do the most damage?”



THREAT PROFILE



Threat Landscape

How are cyber threats evolving on a global scale?



Sectors



Industries



Regions

We're back!



Compromise Trends

Sector/Industry

Generic and Geo-Specific

1. THREAT LANDSCAPE OVERVIEW

- 1.1 Prime Threats
- 1.2 Key Trends
- 1.3 EU Proximity of Prime Threats
- 1.4 Major Threats per Sector
- 1.5 Methodology
- 1.6 Structure of the Report

2. THREAT ACTOR TRENDS

- 2.1 State-Sponsored Actors
- 2.2 Cybercriminals
- 2.3 Hacker-For-Hire Actors
- 2.4 Hacktivists

3. RANSOMWARE

- 3.1 Trends
- 3.2 Recommendations

ANNEX A: MITRE ATT&CK

ANNEX B: MAJOR INCIDENTS

1. INTRODUCTION

2. WHAT IS A SUPPLY CHAIN ATTACK?

- 2.1. Taxonomy of Supply Chain Attacks
- 2.2. Attack Techniques Used To Compromise a Supply Chain
- 2.3. Supplier Assets Targeted by a Supply Chain Attack
- 2.4. Attack Techniques Used to Compromise a Customer
- 2.5. Customer Assets Targeted by a Supply Chain Attack
- 2.6. How to Make Use of the Taxonomy
- 2.7. Supply Chain Taxonomy and other Frameworks

3. THE LIFECYCLE OF A SUPPLY CHAIN ATTACK

4. PROMINENT SUPPLY CHAIN ATTACKS

- 4.1. Solarwinds Orion: IT Management and Remote Monitoring
- 4.2. Mimecast: Cloud Cybersecurity Services
- 4.3. Ledger: Hardware Wallet
- 4.4. Kaseya: IT Management Services Compromised With Ransomware
- 4.5. An Example of Many Unknowns: SITA Passenger Service System

5. ANALYSIS OF SUPPLY CHAIN INCIDENTS

- 5.1. Timeline of Supply Chain Attacks
- 5.2. Understanding the Flow of Attacks
- 5.3. Goal Oriented Attackers
- 5.4. Most Attack Vectors to Compromise Suppliers Remain Unknown
- 5.5. Sophisticated Attacks Attributed To Apt Groups



Threat Models

Where will our adversaries attack? How do we deny, dissuade, or disrupt them?



Apps



Cloud



Controls



Infrastructure



Endpoints



Threat Profile

What impact can these cyber threats have on my organization specifically?



People



Customer Data



Services



Reputation



Revenue

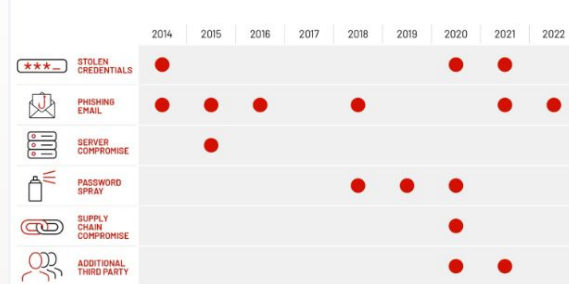
THREAT PROFILE

TABLE OF CONTENTS

PURPOSE	3
EXECUTIVE SUMMARY	4
Background	4
Key Strategic Threats Summary	4
CYBER THREAT LANDSCAPE OVERVIEW	5
Cyber Crime	6
Cyber Espionage	7
China	7
Russia	7
North Korea	7
Key Strategic Threats	7
Theft of PII and PCI	7
Threats to Mobile and Point-of-Sale (PoS) Applications	8
Ransomware Used to Disrupt Business Operations	8
Threat Industry Outlook	8
ATTACK LIFECYCLE AND DEFENSIVE STRATEGIES	8
PRIMARY SECURITY CONTROLS	10
Network-Based Controls	10
Host-Based Controls	10
Security Data Aggregation and Visibility	10
APPENDIX A: CRITERIA FOR ANALYTIC JUDGEMENTS	11
APPENDIX B: GUIDANCE FOR UPDATING THREAT PROFILE	12
APPENDIX C: MITRE ATT&CK MAPPING	23
MANDIANT THREAT INTELLIGENCE REPORTS	30

[illegible]

Initial Infection Vectors Used by APT29



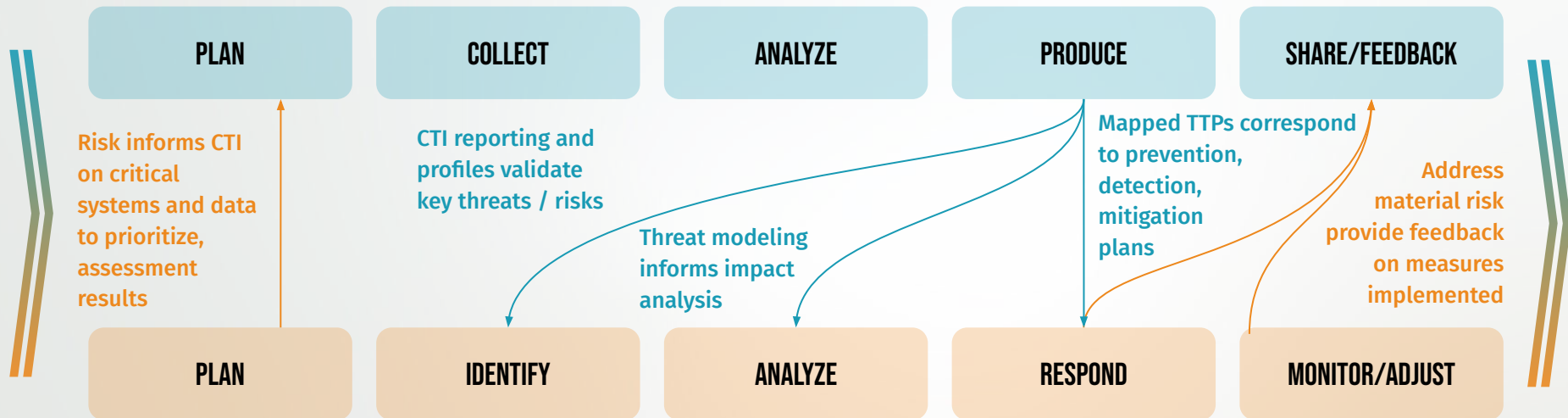
RESPONSIBILITY ASSIGNMENT MATRIX

Responsible, Accountable, Consulted, Informed

Clarifies which individuals or groups are responsible for a project's successful completion, and the roles that each will play throughout the project.

ACTIVITY	RESPONSIBLE	ACCOUNTABLE	CONSULTED	INFORMED
Identify and document cyber threat factors	CTI	CTI	IT Leadership	Risk
Lead cyber risk assessments	Risk	Risk	CTI	IT Leadership
Develop threat models	IT Security	IT Security	Risk & CTI	IT Leadership
Validate cyber threats to crown jewels	CTI (or red team)	Risk	Risk	IT Leadership

ALL TOGETHER NOW



Understand the threats associated with the industry and to the organization, how they are used, and whether existing security controls are in place to blend CTI and Risk roles together.

DISCUSSION

- 1 ? Which tools and approaches could you implement to support risk?
- 2 ? What results would benefit your risk management team the most?
- 3 ? How can vendor or open source intelligence augment existing service support for risk management?

NOT ALL VULNERABILITIES SHOULD BE WEIGHED EQUALLY

FIRST's Common Vulnerability Scoring System (CVSS) attempts to evaluate the severity for Common Vulnerabilities and Exposures (CVEs).

- The results are stored in NIST's National Vulnerability Database (NVD).
- Example: [CVE-2023-36802](#)

FIRST's Exploit Prediction Scoring System (EPSS) attempts to estimate the likelihood that a software vulnerability will be exploited in the wild.

CISA's [Known Exploited Vulnerabilities \(KEV\) catalog](#) only identifies affected products.

- While useful for prioritization, it isn't mapped to threat actor group's exploiting them.

CVE-2023-36802 Detail

Description

Microsoft Streaming Service Proxy Elevation of Privilege Vulnerability

Severity

CVSS Version 3.x

CVSS Version 2.0

CVSS 3.x Severity and Metrics:



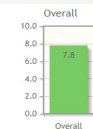
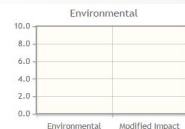
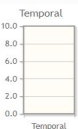
CNA: Microsoft Corporation

Base Score: **7.8 HIGH**

Vector: CVSS:3.1/AV:L/AC:L/PR:L/UI:N/S:U/C:H/I:H/A:H

NVD Analysts use publicly available information to associate vector strings and CVSS scores. We also display any CVSS information provided within the CVE List from the CNA.

Note: The CNA providing a score has achieved an Acceptance Level of Provider. The NVD will only audit a subset of scores provided by this CNA.



CVSS Base Score: 7.8
Impact Subscore: 5.9
Exploitability Subscore: 1.8
CVSS Temporal Score: NA
CVSS Environmental Score: NA
Modified Impact Subscore: NA
Overall CVSS Score: 7.8

Hyperlink

<https://msrc.microsoft.com/update-guide/vulnerability/CVE-2023-36802>

Resource

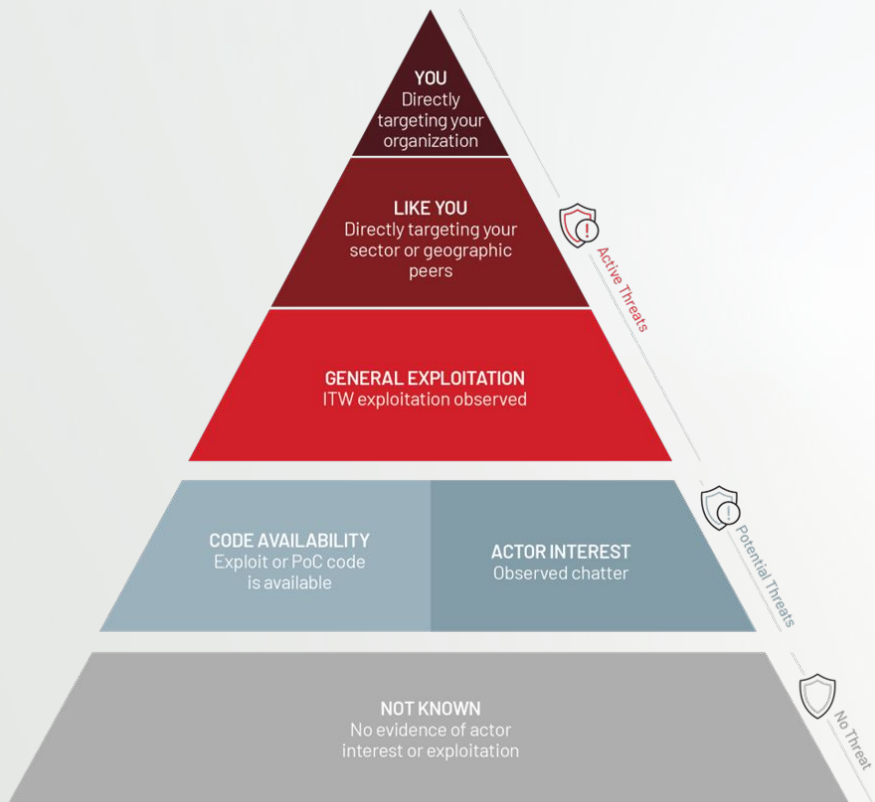
[Patch](#) [Vendor Advisory](#)

This CVE is in CISA's Known Exploited Vulnerabilities Catalog

Reference CISA's BOD 22-01 and Known Exploited Vulnerabilities Catalog for further guidance and requirements.

Vulnerability Name	Date Added	Due Date	Required Action
Microsoft Streaming Service Proxy Privilege Escalation Vulnerability	09/12/2023	10/03/2023	Apply mitigations per vendor instructions or discontinue use of the product if mitigations are unavailable.

NOT ALL VULNERABILITIES SHOULD BE WEIGHED EQUALLY



Rating	Description
No Known	No known exploitation activity, underground discussions, proof of concept (PoC) or exploit code, but has a low potential for exploitation.
Anticipated	No known exploitation activity, underground discussions, PoC or exploit code, but has a high potential for exploitation.
Available	Exploit or PoC code is publicly available or underground discussions, alleged selling, or alleged privately held code observed.
Confirmed	Limited reported or confirmed exploitation activities.
Wide	Exploitation has been reported or confirmed to widely occur.

Wide	0	2	2	1
Confirmed	3	3	2	0
Available	4	4	2	0
Anticipated	0	0	0	0
No Known	8	5	3	0
	Low	Medium	High	Critical

NOT ALL VULNERABILITIES SHOULD BE WEIGHED EQUALLY

	Mandiant Risk Ratings				NVD CVSSv3.x Ratings			
	2019	2020	2021	2022	2019	2020	2021	2022
low	5723	6598	6855	5408	180	294	287	184
medium	2533	3377	3630	2762	3318	4286	4326	3410
high	177	314	382	428	3795	4659	5275	4140
critical	1	2	2	0	1141	1052	981	864

RISK-ADJUSTED VULNERABILITY PROCESS

External Data

Internal Data

Result

- 1 Take all known vuln info and scope the list down to only what is in your environment

NVD: CVE #, Score,
Affected Software

CMDB + Asset Inventory
+ Vuln Scan Data

=



Relevant
vulnerabilities

- 2 Identify threat actors exploiting these vulns to determine use and prioritization

OSINT (e.g. KEV,
Shadowserver, Greynoise)
Vendor Intelligence

Cyber Threat Profile

=



Prioritized
vulnerabilities

- 3 Determine whether technical controls prevent/detect usage. Identify if compensatory controls negate remaining vulnerability exploitation.

Risk Register
Security Controls

=



Remaining Exposed
Attack Surface

CASE STUDY

ASSESSING HIGH SEVERITY VULNERABILITIES

Severity ≠ Exploitability Scenario

- Cisco releases 13 bugs and patches
- CTI contextualizes severity
- Exploitation assessment and contextualization of each for relevance to organizational crown jewels

Example: Remote Code Execution

- In isolation: **HIGH** severity rating
- Not observed in wild and privileges required to exploit: overall **LOW** risk

CASE STUDY

ASSESSING HIGH SEVERITY VULNERABILITIES

SITUATION REQUIRING ASSESSMENT	CTI CONTRIBUTION	SIMPLE RISK ASSESSMENT	CROWN JEWEL IMPACT
A command injection vulnerability exists in the Web UI component of Cisco IOS XE versions 16.11.1 and earlier that, when exploited, allows a privileged attacker to remotely execute arbitrary commands with root privileges (CVE-2019-12650). NVD rated this vulnerability to be "high" risk.	CTI rated it as low risk because it requires the highest level of privileges—level 15 admin privileges—to exploit. Because this level of <u>access should be quite limited</u> in enterprise environments, we believe that it is <u>unlikely</u> attackers would be able to leverage this vulnerability as easily as others. There is <u>no known exploitation</u> of this activity.	Frequency - No known - Future exploitation unlikely Severity - High	NO

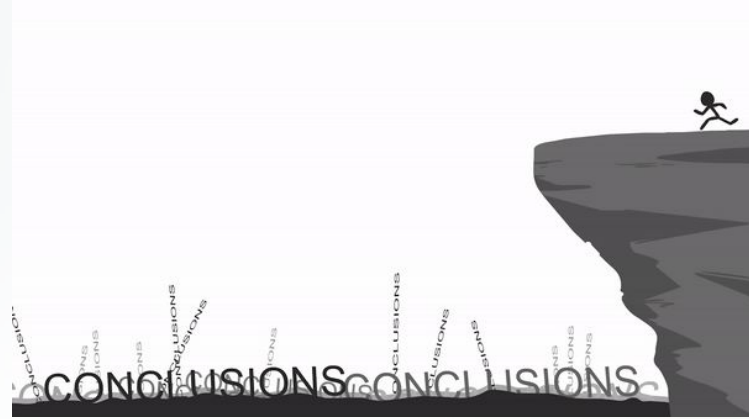
Recommendation: Mitigate the risk through patching, and accept the risk until the patch is implemented. The patching schedule likely does not need to be accelerated in this case given low likelihood of exploitation.

CHAPTER 5 : THE WIND OF CHANGE IS STRANGE

Ft. Legolas on Guitar



CONCLUSION



**EXAMPLES, KEY LESSONS
AND TAKEAWAYS.**

CASE STUDY

SUPPLY CHAIN RISKS & DEVELOPER ENVIRONMENTS

Building a Software Team from 0

- Exec team wants to understand risks
- Prominent use of open-source tools and software dependencies makes supply chain security a key issue

CTI & Risk Actions

- Provide Supply Chain Risk assessment
- Help identify peer and third party incidents to demonstrate org, sector, regional threat relevance
- Support defense with up-to-date TTPs
- Recommend and build successful resiliency measures

CASE STUDY

SUPPLY CHAIN RISKS & DEVELOPER ENVIRONMENTS

SITUATION REQUIRING ASSESSMENT	CTI CONTRIBUTION	SIMPLE RISK ASSESSMENT	CROWN JEWEL IMPACT
Supply chain risks associated with developer environments and interest in developing software team	Since 2013 supply chain risks associated with developer environments have grown significantly in both frequency and severity. This includes targeting of both open-source libraries and developer tools across a range of sectors and regions. During this period, threat actors have continually improved their compromise tactics and tools. Typical post-compromise activity includes credential theft and the deployment of cryptominers.	Frequency - Moderate and increasing Severity - High	HIGH PROBABILITY

Recommendations include mitigation steps, for example:

- Utilize SBOM methods to document, understand, and track build components associated with application development.
- Establish a change control process and board for all enterprise hardware and software changes. (E.g. centralized IT or IT security managed process for downloading, testing, and pushing updates out to users.)
- Use an advanced endpoint security solution, such as EDR, to detect malicious behavior if a tainted software package is Dled and executed.
- Security assessments and audits should be an integral part of the software development lifecycle or continuous integration and deployment (CI/CD) pipeline for any internally developed software that is customer facing or integral to internal functions of the organization.

CASE STUDY

**RANSOMWARE RISK &
INSURANCE****Planning for Cyber Insurance**

- Exec team evaluating different insurance policies to transfer ransomware attack risk
- Need to understand insurance's role in ransomware risk mitigation, as a last resort for worst-case scenario

CTI & Risk Actions

- Current ransomware risk assessment
- Help identify peer and third party ransomware incidents to demonstrate org, sector, regional threat relevance
- Support defense with up-to-date TTPs
- Recommend and build successful resiliency measures (e.g. offsite backups, TTXs, off-hours intrusion plan)

CASE STUDY

RANSOMWARE RISK & INSURANCE

SITUATION REQUIRING ASSESSMENT	CTI CONTRIBUTION	SIMPLE RISK ASSESSMENT	CROWN JEWEL IMPACT
Ransomware and multifaceted extortion	Since 2017 ransomware operations have grown significantly in both frequency and severity. Observed ransomware operations have affected both small and large organizations in nearly every sector and region. During this time, threat actors have continually improved their compromise tactics and tools as well as strategies for increasing leverage against victims.	Frequency - High Severity - High	HIGH PROBABILITY

Recommendations:

- Mitigate the organization's vulnerability to ransomware TTPs, including initial infection vectors and malware or pivoting tactics that frequently precede data theft and ransomware encryption deployment.
- Institute and test backup and after hours incident response plans to enhance the organization's resiliency in the event of a compromise.
- Explore cyber insurance options for transferring some risk.

TEMPLATE YOUR ORGANIZATION

SITUATION REQUIRING ASSESSMENT	CTI CONTRIBUTION	SIMPLE RISK ASSESSMENT	CROWN JEWEL IMPACT
??	??	Frequency -	PROBABILITY
		Severity -	



Thoughtful310 · 9 hr. ago

As a GRC Manager, I worked really closely with the CTI team at one job. We mapped the MITRE ATT&CK framework against the controls we used to measure maturity. They identified the top TTPs used against our company and our industry. We used this information to prioritize control mitigation projects.

They also scoured the dark web for company information, for company emails in lists of compromised credentials, etc. They were active in ISAC meetings so they were information sharing with other companies in our industry.

That's in addition to the usual security bulletin notifications to IT on new vulns, farming through the Mandiant data, etc.

I consulted them on whether new policies were needed based on risks and they would do an assessment of risk in that particular area.

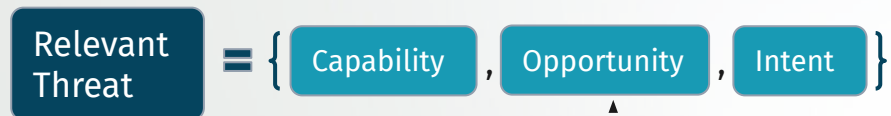
6. They think the funding for the CTI function would be better spent on security products and capabilities. Ultimately building a CTI function is about an organization and their leadership accepting that you'll never be able to secure every asset of theirs, all the time. This means moving to a risk based cybersecurity posture. CTI ultimately is about reducing risk for an organization, i.e. attempting to reduce the likelihood of a cybersecurity event occurring and/or the impact of the event if it happens.

Threat intel is great when it takes intel, and passes that to monitoring teams in a way that they can formulate monitoring use cases. Same with security testers; tell them what attacks are happening and the testers can try them out. And risk people; good threat intel means my risk assessments are better because I have a more accurate idea of what risks are relevant.

RECAP

The shared goal is risk reduction.

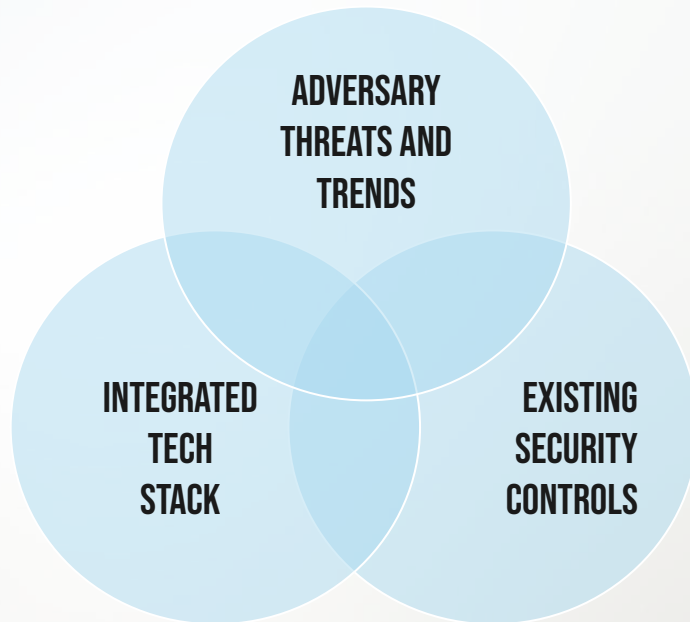
Threats are an input into overall risk.



Organisations can only control **1** of these variables, but...

a reduction in any of the three drives down overall threat and provides a more scoped focus for risk management decisions

CYBER RISK



RECAP

WHY DON'T YOU
JUST MEET ME
IN THE MIDDLE

Cyber Security and CTI

- Diamond Model of Intrusion Analysis
- MITRE ATT&CK
- Lockheed Martin's Cyber Kill Chain
- The Mandiant Targeted Attack Lifecycle
- The Unified Cyber Kill Chain

Factor Analysis of
Information Risk (FAIR)
Cyber Risk Quantification
Model

Vocabulary for Event
Recording and Incident
Sharing (VERIS)

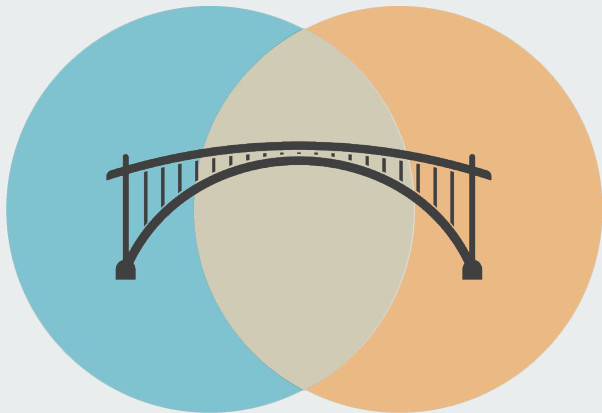
ISF Quantitative Techniques
in Information Risk Analysis

OWASP's Risk Rating
Methodology

Risk Management

- NIST Risk Management Framework
- NIST Risk Framework Profiles

CTI + RISK



CONNECTORS: CHAMPIONS & ADVOCATES



SHARED PURPOSE, COMMON LANGUAGE



EMBED PARTNERSHIP IN THE PROCESS



DEMONSTRATE ROI

FINAL DISCUSSION

- ? What are your key takeaways from today?
- ? What next steps will you take with your risk management team?



QUESTIONS?

BONUS ASK



Survey on CTI Networking

Context
This survey is a follow-up to my 2022 research on intelligence networking practices, results, and challenges. The full 2022 report is [Sharing Caring?](#) and the SANS 2022 [CTI Summit Presentation](#).

Purpose
Security teams cannot sustainably network if they do not have a discourse around how cyber threat intelligence is shared, defense, collective resilience, and the future of the field.

Yet, the enormity of it all is often overlooked. We need to effectively network "to connect the dots" and fill the gaps. This survey is a first step.

TAKE THE SURVEY

 [BIT.LY/CTISURVEY23](https://bit.ly/CTISURVEY23)



GET IN TOUCH



JOHN DOYLE

@_John_Doyle

in/john-doyle-a02bab10/



JAMIE COLLIER

@TheCollierJam

in/collierjs



GRACE CHI

@euphoricfall

in/graceschi

grace@pulsedive.com



THANKS!

